

Internet of Things Security

FINAL THESIS REPORT

Thesis

Submitted in partial fulfillment of the requirements of
BITS F423T/424T Thesis

By

KATTA SATHVIK REDDY

ID No. 2020A7TS0191H

Under the supervision of

Dr Jay Kamlesh Dave



**BIRLA INSTITUTE OF TECHNOLOGY AND SCIENCE, PILANI
HYDERABAD CAMPUS**

December 2024..



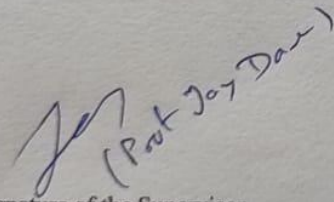
Birla Institute of Technology & Science, Pilani
Hyderabad Campus

(Date)

Format of 'Certificate from the Supervisor'

CERTIFICATE

This is to certify that the thesis entitled
"Internet of things - Security" submitted
by K. Sathvik Reddy ID No 2020A7T50191H in partial fulfilment of the
requirement of BITS F423T/424T Thesis embodies the original work done by him/her under my
supervision.


(Prof. Joy Datta)

Signature of the Supervisor

Name & Designation

Date: 7 OCT-2024

Signature of the Co-supervisor

Name & Designation

Date:

Acknowledgement

I am grateful to my supervisor Prof Jay Kamlesh Dave for his continuous support and valuable feedback and guidance thought the project. I would also like to thank my colleagues and friends for their support and encouragement in this endeavor.

K SATHVIK REDDY
2020A7TS0191H
1ST SEMESTER
BITS PILANI
DECEMBER 2024

Abstract

The Internet of Things (IoT) has transformed modern technology by enabling interconnection of devices, transforming industries, and enhancing daily life. However, the rapid expansion of IoT devices has introduced significant security vulnerabilities and issues, making them prime targets for innumerable cyberattacks. This thesis report builds upon the previous mid semester report and even explores the integration of artificial intelligence (AI) and machine learning (ML) into Intrusion Detection Systems (IDS) to strengthen IoT security. So there are many thing that are similar to and taken from the previous report.

The report begins by analysing the unique challenges in securing IoT environments, including constrained device resources, diverse architectures, and the dynamic nature of threats. Key attack vectors, such as Distributed Denial of Service (DDoS), Man-in-the-Middle (MITM), and advanced malware, are reviewed to establish a comprehensive understanding of the IoT threat landscape.

Central to this work is the application of AI/ML to IDS for real-time threat detection and prevention. The report investigates preexisting machine learning models for anomaly detection, including supervised, unsupervised, and reinforcement learning techniques, which enable the system to identify irregular patterns indicative of attacks. Deep learning architectures such as Convolutional Neural Networks (CNNs) and Recurrent Neural Networks (RNNs) will be used for their ability to process vast IoT data streams efficiently.

Furthermore, the report examines cryptographic and blockchain protection methods to enhance privacy. The integration of edge computing with AI/ML is also discussed, emphasizing reduced latency and improved scalability in IDS deployment.

Through case studies and experimental evaluations, the research demonstrates how AI-driven IDS solutions can detect, mitigate, and adapt to evolving threats in IoT ecosystems. The findings highlight the potential of modern security frameworks to create robust, autonomous security frameworks while addressing challenges such as computational efficiency and model accuracy.

Overall, this report is a more comprehensive and detailed exploration into the topic of security in Internet of things from architecture to attacks and solutions.

This paper proposes LAKE-ECC (Lightweight Authenticated Key Exchange over Elliptic Curve Cryptography), a session key establishment protocol designed specifically for resource-constrained IoT nodes.

LAKE-ECC is built on Elliptic Curve Diffie-Hellman (ECDH) over the NIST P-256 curve, augmented with a Schnorr-based mutual authentication scheme and a BLAKE2s-derived session key. The protocol achieves forward secrecy, mutual authentication, and replay attack resistance while limiting message size to under 256 bytes and requiring no persistent public-key infrastructure (PKI) on the device. Security is grounded in the Elliptic Curve Discrete Logarithm Problem (ECDLP) and formally modeled under the Canetti-Krawczyk (CK) security framework.

We further introduce a mathematical anomaly detection layer, a Mahalanobis-distance-based behavioral fingerprinting mechanism

List of Symbols & Abbreviations used

IoT-related Terms

- **IoT** – Internet of Things
- **IIoT** – Industrial Internet of Things
- **M2M** – Machine-to-Machine communication
- **WSN** – Wireless Sensor Network

Security Mechanisms

- **AES** – Advanced Encryption Standard
- **RSA** – Rivest–Shamir–Adleman (encryption algorithm)
- **TLS** – Transport Layer Security
- **IDS** – Intrusion Detection System
- **IPS** – Intrusion Prevention System

Network and Communication Protocols

- **HTTP** – Hypertext Transfer Protocol
- **HTTPS** – Hypertext Transfer Protocol Secure
- **MQTT** – Message Queuing Telemetry Transport
- **NFC** – Near Field Communication
- **ZigBee** – A low-power wireless communication protocol
- **Lora WAN** – Long Range Wide Area Network

General Technical Terms

- **CPU** – Central Processing Unit
- **RAM** – Random Access Memory
- **MAC** – Media Access
- **API** – Application Programming Interface
- **MITM** - Man in the middle attack
- **DoS** – Denial of Service
- **DDoS** – Distributed Denial of Service
- **VPN** – Virtual Private Network
- **CPS** – Cyber-Physical Systems
- **AI** – Artificial Intelligence
- **ML** – Machine Learning
- **LLM** – Large language models
- **MLP** - Multilayer Perceptron
- **MKKM-IC**- Multi Kernel K-means
- **SVM** – Support vector machine
- **UDP** – User datagram protocol

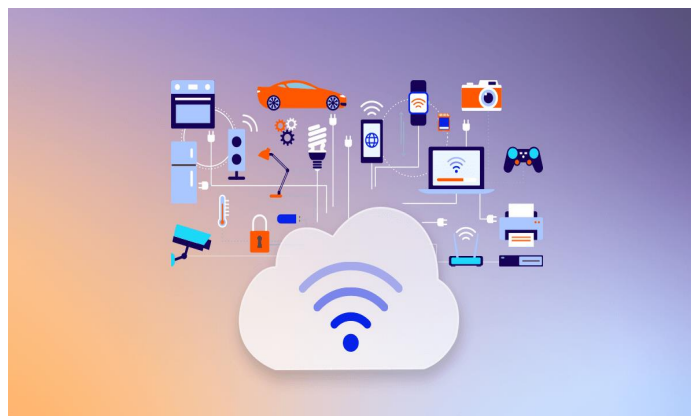
Note: More abbreviations are included in the report

Table of Contents

- Thesis title/cover page
- Certificate (to be added later)
- Acknowledgement
- Abstract
- Introduction
- Background of work
- Solutions, Analysis and results
- Conclusion
- Bibliography and references

1. INTRODUCTION

As discussed previously in the midsem report the word internet of things(IOT) is coined by Kevin Ashton. **Internet of things (IoT)** encapsulates devices with sensors attached which contain internal software, processing abilities and technologies that connect and exchange data with other devices and systems. They play a crucial role in connecting virtual and physical systems together using communication networks. These devices range from everyday consumer products like smart thermostats, smart watches, wearable health trackers, and home automation systems, to industrial applications such as smart manufacturing, logistics, and healthcare monitoring. Some real-life examples of IOT include monitoring environmental conditions in farms, controlling machines and processes in factories, tracking inventory and shipments in warehouses and monitoring health conditions of patients etc. The connectivity, efficiency and data-sharing capabilities of IoT management devices have revolutionized industries, enabling smarter decision-making, increased automation, and enhanced user experiences. This has revolutionized many sectors offering high efficiency and convenience to the customers. The main goal of the IoT is the unification of many and numerous domains under the same name called smart life or smart life style. Scientists are even imagining smart cities founded on IOT technologies.



The IoT simplifies and automates various tasks that are extremely complicated and sometimes beyond the scope of human capabilities. Today there are more than 20 billion IOT devices across the world in various countries with the USA, China and Europe accounting up to 80% of them. The world's first IOT device is commonly considered to be the toaster created by John Romkey in 1990. The toaster could be turned on whenever we want and off over the internet. It was connected to a computer using a TCP/IP protocol. Romkey presented the toaster at the October 1989 INTEROP conference. The four main key components of IOT are Device/sensors, connectivity, data processing and Interface. Sensors are a very important part of any IoT application. It is a non-digital device that measures, quantifies and detects certain physical entities and converts them into signal-based frequencies which can be provided as an input to the processing or can be used to control unit for analysis purpose.

1.0.1 Thesis Contributions and Organization

This thesis focuses on examining the role of Internet of Things (IoT) technologies in supporting individuals with disabilities, with particular emphasis on privacy and security considerations. The work first identifies and classifies a wide range of IoT applications developed for assisting people with disabilities. It then analyzes the major privacy and security challenges associated with these applications and reviews existing technical solutions that aim to address these challenges. Based on this analysis, the thesis further identifies a set of privacy and security requirements that should be considered when designing IoT systems intended for disabled users.

The thesis begins with an overview of the relationship between privacy and security and their importance in IoT environments. This is followed by a discussion of IoT architecture and its core components. The types of disabilities commonly encountered in daily life and the ways in which IoT applications can assist are then described. Subsequently, the major privacy and security issues affecting such applications are examined, along with the requirements necessary to mitigate these risks. The thesis concludes with a summary of findings and final remarks.

1.1 Applications of IOT

There are many practical applications of IOT devices in both public and private sectors that make people's day-to-day lives easier.

1. Home Automation

IoT devices enhance convenience and efficiency in homes by automating and remotely controlling appliances. For example, smart thermostats optimize heating or cooling based on user preferences, reducing energy consumption. Smart lighting systems adjust brightness or switch off when not in use, and IoT-enabled security cameras provide real-time monitoring and alerts. Voice assistants integrate these devices, allowing seamless operation through voice commands, creating an interconnected and intelligent living environment.

2. Healthcare

IoT is revolutionizing healthcare by enabling continuous monitoring and real-time data analysis. Wearable devices like smartwatches and fitness bands collect health metrics such as heart rate and blood pressure, providing early warnings for potential health issues. Remote patient monitoring systems send health data to physicians, facilitating timely interventions for chronic disease management. IoT-enabled medical equipment, such as smart insulin pumps, ensures precise delivery of treatment and reduces the need for frequent hospital visits.

3. Agriculture

IoT in agriculture optimizes resource utilization and boosts productivity through data-driven decisions. Soil moisture sensors communicate with automated irrigation systems to provide precise watering, preventing over- or under-watering. Weather monitoring stations offer real-time climatic updates, enabling farmers to plan their activities effectively. Livestock tracking devices monitor animal health and movement, helping prevent disease outbreaks and ensuring efficient herd management.

4. Industry (Industrial IoT)

Industrial IoT improves operational efficiency and minimizes downtime through smart monitoring and automation. Predictive maintenance systems use sensors to detect equipment malfunctions before they occur, reducing repair costs and delays. Real-time monitoring of production processes ensures optimal performance and waste reduction. Additionally, IoT streamlines supply chain management by tracking inventory and shipments, enhancing overall productivity.

5. Smart Cities

IoT enables urban sustainability and efficiency through interconnected systems. Smart traffic management systems adjust signals dynamically based on real-time data to reduce congestion and travel time. IoT-enabled waste management uses sensors in garbage bins to optimize collection routes, saving time and resources. Smart grids monitor and balance energy supply, current, voltage and demand, integrating non-renewable and renewable energy sources to minimize carbon footprints and reduce costs.

6. Transportation

IoT transforms transportation by improving safety, reliability, and efficiency. Connected vehicles share data on traffic conditions and road safety, enabling faster navigation and reduced accidents. IoT-based fleet management systems will optimize routes, improve efficiency and monitor vehicle health to improve logistics. In public transportation, IoT systems provide real-time tracking of buses and trains, enhancing commuter experience with accurate arrival updates and improved scheduling.

7. Smart Retail

IoT is reshaping retail by enhancing customer experience and streamlining operations. Smart shelves equipped with weight sensors track inventory levels in real time, ensuring timely restocking. IoT-enabled beacons send personalized offers to customers' smartphones based on their location within the store. Automated checkout systems use RFID or IoT-based scanning to enable quick, hassle-free transactions. Additionally, smart monitoring systems analyse foot traffic and customer behaviour, helping retailers optimize store layouts and marketing strategies.

8. Smart Grid

IoT in smart grids optimizes energy distribution and consumption for greater efficiency and sustainability. Smart meters collect real-time data on electricity usage, enabling dynamic pricing and encouraging energy conservation. IoT sensors monitor grid health and detect faults, minimizing downtime through predictive maintenance. By integrating renewable energy sources, smart grids will balance supply and demand and efficiency, reducing our excessive reliance on fossil fuels and supporting green energy initiatives.

1.2 Architecture of IOT

The architectural structure of IOT is not rigid but mainly divided into various layers like perception layer, application layer, network layer, some researchers propose even more layers like the sensing layer, presentation layer, transport layer, middleware Layer and Gateway

Layer etc. The 7-layer IoT architectural view, also known as the Open System Interconnection (OSI) model, is a new representation of the IoT architecture layers. This layer architecture of IoT is designed to tackle the various challenges of IoT systems by providing a clear structure for data flow, security, and efficiency.

Perception layer

- **Purpose:** This is the physical layer that includes sensors, actuators, and IoT devices. These devices collect data from the physical environment, such as temperature, humidity, motion, or location.
- **Components:** Sensors, RFID tags, cameras, GPS devices, actuators.
- **Function:** Captures and transmits data from the physical world for further processing.

Network Layer

- **Purpose:** This layer is always responsible for transmitting the various types of data collected by the perception layer to other layers, usually using various communication protocols.
- **Components:** Routers, gateways, communication protocols (Wi-Fi, Bluetooth, ZigBee, LPWAN, 4G/5G, Lora WAN).
- **Function:** Facilitates the data transfer between multiple IoT devices and other network components, ensuring communication between cloud and devices or edge infrastructure.

Processing Layer (Middleware Layer)

- **Purpose:** This layer handles the analysis and processing of the data collected. It can occur either at the edge with (edge computing) or in the cloud (cloud computing). In some systems, this includes real-time data analysis.
- **Components:** Edge devices, cloud servers, databases, data analytics tools, middleware.
- **Function:** Processes raw data into meaningful insights and performs actions based on the data. It also manages resources and handles data storage.

Application Layer

- **Purpose:** The application layer interfaces with users and provides specific services. It directly interacts with applications such as smart homes etc.
- **Components:** Application software for smart homes, healthcare, industrial control, etc.
- **Function:** Delivers application-specific services to the end-users or systems, for instance, monitoring patient health in healthcare, or controlling smart devices in homes.

Transportation Layer

- **Purpose:** Facilitates the seamless movement of data packets across networks to ensure communication.

- **Components:** Transport protocols like TCP/IP, UDP, MQTT, and CoAP.
- **Function:** Ensures reliable delivery of data between IoT devices and servers. Manages bandwidth, latency, and error correction to optimize communication. Supports lightweight protocols like MQTT for resource-constrained IoT environments.

Security Layer

- **Purpose:** Although not always considered a distinct layer, security is integral to every part of the IoT architecture. This layer ensures the protection of data, devices, and networks.
- **Components:** Encryption protocols, authentication systems, firewalls, intrusion detection systems.
- **Function:** Protects data from unauthorized access, ensures secure communication, and defends against cyber threats and breaches.

Layer Interactions

- **Perception to Network:** The perception layer collects data, which is transmitted to first processing layer via the network layer.
- **Network to Processing:** The processing layer analyses the data and generates insights, sending actionable commands back through the network layer.
- **Processing to Application:** Insights from the processing layer are delivered to end users via the application layer.
- **Security Across Layers:** Security mechanisms operate at each layer to ensure data privacy, integrity, and system reliability.

This layered architecture ensures modularity, scalability, and flexibility in IoT systems, enabling efficient interaction between devices, networks, and applications while maintaining robust security.

There are many number of key technologies that play a crucial role in enhancing and enabling the IOT devices

1. Wireless Sensor Networks (WSNs)

WSNs consist of multiple distributed sensors that collect and store and transmit data about environmental conditions like temperature, weather, humidity, and motion. These networks are fundamental to IoT as they will enable real-time data collection and monitoring for many applications such as agriculture, healthcare, and smart life cities.

2. Radio Frequency Identification (RFID)

RFID uses various electromagnetic fields to identify, locate and track objects equipped with RFID tags. It is widely used in inventory management, supply chains, and retail for real-time asset tracking and automation. RFID's ability to communicate without line-of-sight is crucial for IoT-enabled logistics.

5. 6LoWPAN (IPv6 over Low-Power Wireless Personal Area Networks)

6LoWPAN allows IoT devices to communicate over low-power wireless networks using the IPv6 protocol. It enables efficient connectivity for battery-operated devices in smart homes and industrial IoT applications.

6. Near Field Communication (NFC)

NFC is the most efficient short-range communication technology used for secure data transfer and authentication. It is popular in contactless payments, smart cards, and wearable devices, enabling seamless integration with IoT ecosystems.

7. Constrained Application Protocol (CoAP)

CoAP is a lightweight protocol designed for limited and resource-constrained smart IoT devices. It mostly operates over UDP, providing efficient communication for applications such as smart lighting and energy monitoring.

1.3 Data Processing in IoT Devices: Cloud vs. Edge

IoT data processing involves collecting, analysing, and deriving actionable insights from data generated by devices. This process can occur in centralized cloud platforms or at the edge of the network, near the data source. Each approach has distinct characteristics and applications.

1. Cloud Computing for IoT

Cloud computing processes and stores IoT data on centralized servers, often located in remote data centres.

Key Features:

- **Centralized Processing:** Data from IoT devices is mostly transmitted to the cloud for analysis.
- **Scalability:** The cloud can handle vast amounts of data and supports complex computational tasks, making it ideal for large-scale IoT deployments.
- **Integration with AI/ML:** Cloud platforms facilitate advanced machine learning and artificial intelligence models, enabling predictive analytics and decision-making.
- **Massive Storage:** Offers extensive storage for historical and real-time data, enabling long-term analysis and trend identification.

Advantages:

- **High Computational Power:** Cloud servers can handle resource-intensive tasks that IoT devices cannot.
- **Global Accessibility:** Data and applications are accessible from anywhere via the internet.
- **Data Backup and Recovery:** The cloud provides robust backup systems, ensuring data reliability.

Challenges:

- **Latency:** Data transmission to and from the overall cloud introduces delays, which can be problematic for real-time applications like autonomous vehicles.
- **Bandwidth Costs:** Transmitting large volumes of data can be costly and bandwidth intensive.
- **Privacy Concerns:** Mainly storing sensitive data in the cloud will raise concerns about data security and compliance, agreement with regulations like GDPR.

Applications:

- Smart city infrastructure (e.g., traffic monitoring and management).
- Long-term data analysis in healthcare (e.g., patient history aggregation).
- Industrial IoT for predictive maintenance at a large scale.

2. Edge Computing for IoT

Edge is a process of computing data mostly locally on IoT devices or nearby edge servers, mainly reducing the dependency on centralized cloud platforms.

Key Features:

- **Localized Processing:** Data is analysed close to where it is generated, such as on IoT devices, edge gateways, or edge servers.
- **Real-Time Insights:** Processes data with minimal latency, making it suitable for time-sensitive applications.
- **Data Reduction:** Only processed or critical data is sent to the cloud, reducing bandwidth usage.

Advantages:

- **Low Latency:** By processing data locally, edge computing provides immediate responses, critical for applications like autonomous vehicles or industrial automation.
- **Improved Privacy:** Sensitive data can be processed locally without leaving the device, reducing exposure to cyber threats.
- **Bandwidth Efficiency:** Edge devices transmit only relevant data to the cloud, optimizing network usage.

Challenges:

- **Limited Computational Resources:** Edge devices may lack the processing power of cloud servers, limiting their ability to handle complex tasks.
- **Deployment Complexity:** Implementing and maintaining edge infrastructure requires additional resources and expertise.
- **Scalability:** Handling large-scale data analysis may still require cloud integration.

Applications:

- Autonomous systems (e.g., self-driving cars for real-time decision-making).

- Smart manufacturing (e.g., detecting defects in real time).
- Healthcare monitoring (e.g., wearable devices analysing heart rate locally).

Cloud vs. Edge: Comparative Analysis

Feature	Cloud Computing	Edge Computing
Processing Location	Centralized servers in remote data centres.	Local devices or edge servers near the data source.
Latency	Higher due to data transmission.	Minimal due to localized processing.
Scalability	Highly scalable.	Limited by edge device resources.
Data Privacy	Data stored in centralized servers.	Data processed locally, enhancing privacy.
Cost	Higher due to bandwidth and storage.	Lower bandwidth requirements.
Applications	Long-term and resource-intensive tasks.	Real-time and latency-sensitive tasks.

Hybrid Approach

In many IoT systems, cloud and edge computing are used together to optimize efficiency. For instance:

- Edge computing processes real-time data locally, while the cloud stores historical data for long-term analysis.
- A smart home system may use edge devices for immediate responses (e.g., turning off lights) and the cloud for energy consumption trends.

By combining the strengths of both, hybrid architectures enable scalable, secure, and efficient IoT ecosystems tailored to diverse application needs.

1.4 Security in Internet of things

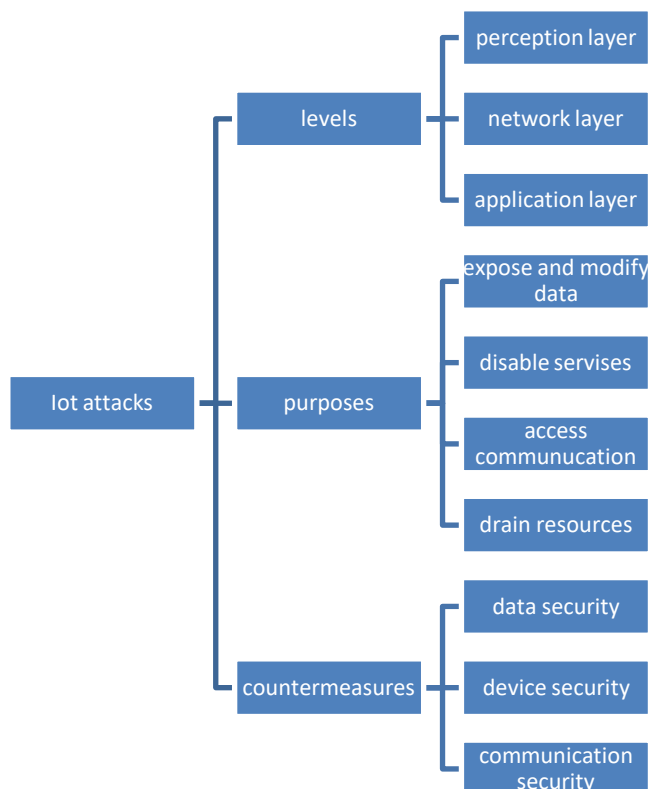
IOT devices have become an integral part of our life, however, the rapid growth in the number of connected devices has introduced new challenges, particularly in terms of security. As billions of devices communicate and share sensitive data, ensuring privacy, integrity, and availability of this data has become critical. The heterogeneity of IoT devices, which vary greatly in terms of computational power and communication protocols, adds complexity to the task of securing these networks. Moreover, the deployment of IoT in critical infrastructure—such as healthcare, transportation, and smart cities—further amplifies the risk, making security breaches potentially catastrophic.

Given this, securing IoT devices is not just a challenge but a fundamental requirement for ensuring the long-term viability and trustworthiness of IoT systems. The previous mid semester report briefly explored current trends in IoT security and a few security mechanisms to protect IoT ecosystems from vulnerabilities. This final report builds on the previous report and covers in depth regarding the prospects of AI/ML and block chain technology. It also reviews preexisting models of Intrusion Detection Systems Using Machine Learning and Deep Learning in Internet of Things and the challenges addressed.

2 BACKGROUND

The history of IoT security dates back to the early 2010s, when the first generation of IoT devices began to gain popularity. Initially, the focus was on the IoT technology itself and its applications. As a result, IoT systems became easy targets for cyberattacks. The first IoT security devices were primarily used for remote surveillance, but as technology advanced, they began to include additional features like intrusion detection and automatic alerts.

There are multiple kinds of attacks in IOT devices which are classified into hierarchies based on their levels, purpose and counter measures. This flowchart from the previous report gives a bird's eye view of it.



Perception layer threats focus on security attacks targeting key IoT components, such as Wireless Sensor Networks (WSNs) and Radio Frequency Identification (RFID) systems. Network layer threats involve exploiting vulnerabilities in communication protocols, potentially disrupting data transmission or network functionality. Application layer threats pertain to attacks on IoT software and end-user devices, often aiming to compromise data integrity or user privacy.

Perception Layer Threats in IoT

The perception layer in IoT architecture includes physical devices like sensors, actuators, RFID tags, and wireless sensor networks (WSNs). These devices gather data from the environment, making them critical for IoT functionality. However, their limited computational resources, heterogeneity, and deployment in exposed environments make them vulnerable to various security threats. WSNs are integral to IoT, often deployed in remote or harsh environments. Common threats include sinkhole, wormhole, blackhole and Dos attacks. RFID tags and readers are key components of IoT systems, particularly in supply chain management and asset tracking. They face spoofing and cloning threats.

Network Layer Threats in IoT

The network layer in IoT is responsible for transmitting data between devices, edge nodes, and cloud systems. It utilizes various communication protocols and technologies like Wi-Fi, Bluetooth, ZigBee, Lora WAN, and cellular networks to ensure seamless data transfer. However, this layer is prone to a variety of security threats that exploit vulnerabilities in routing protocols, data transmission, and communication mechanisms like Dos, DDos, MITM and routing attacks. The ZigBee protocol incorporates security mechanisms such as the Advanced Encryption Standard (AES) with Cipher Block Chaining Message Authentication Code (CBC-MAC) and Message Integrity Code (MIC). Its security framework relies on three types of keys: the master key, link key, and network key. The master key is embedded into the device during manufacturing, while the link key can be generated using key transport or key establishment methods. The network key, on the other hand, is acquired through the key transport method. However, the master key's storage on the IoT device poses a vulnerability; in the event of a successful node capture attack, an attacker could extract the key from the device's memory..

Application Layer Threats in IoT

The application layer in IoT is responsible for interfacing with end-users and enabling services. It ensures data transfer and interaction between devices and applications using various protocols. However, this layer is vulnerable to several security threats due to protocol weaknesses, software vulnerabilities, and the lack of standardized authentication mechanisms. CoAP is widely used for resource-constrained IoT devices to facilitate RESTful interactions. It operates over the UDP transport protocol, which introduces inherent vulnerabilities. Datagram Transport Layer Security (DTLS) provides encryption, authentication, and integrity for CoAP. However, its limitations, such as delayed handshakes and susceptibility to DoS attacks, compromise CoAP's security. MQTT is a lightweight

protocol used for message exchange between IoT devices. Its primary focus is reliability, but its security features remain limited.

2.1 Different types of attacks of devices

We will discuss some of the most common security attacks on IOT devices in detail here. This will explain in detail about the various attacks in comparison to the previous report. They include Malware and Malicious Codes Injection Attacks, wrong and false Data Injection (FDI) Attack, Replay Attack, Cryptanalysis attacks and Side-channel Attacks, Eavesdropping Attack, Distributed Denial of Service (DDoS) Attack, Spoofing Attack, Mans In The Middle (MITM) Attacks, Sinkhole Attacks, Sleep Deprivation Attacks, Node tampering, Node injection, Brute force attack, Phishing attack etc.

Malware and Malicious Code Injection Attacks: These attacks involve injecting malicious software or code into IoT devices, often exploiting vulnerabilities to take control, steal data, or damage systems.

Wrong and False Data Injection (FDI) Attack: In this attack, attackers insert false or manipulated data into the IoT network, misleading systems or users and causing incorrect decisions or actions.

Replay Attack: This involves intercepting and retransmitting valid data or communication packets to deceive systems into accepting outdated or malicious data.

Cryptanalysis and Side-channel Attacks: These attacks target cryptographic systems by analysing physical or timing-related characteristics, such as power consumption, to extract sensitive data like encryption keys.

Eavesdropping Attack: In this attack, attackers intercept communication between IoT devices to listen in on sensitive information, often exploiting unsecured communication channels.

Distributed and Denial of Service (DDoS) Attacks: A DDoS attack overwhelms IoT devices or networks with a floods of traffic from various sources, causing system downtime or disruptions.

Spoofing Attack: This occurs when attackers impersonate legitimate devices or users to gain unauthorized access to IoT systems, often by faking identities or IP addresses.

Man In The Middle (MITM) Attack: Attackers secretly intercept and alter communication between two parties, making them believe they are communicating directly when the attacker is manipulating the information.

Sinkhole Attack: In a sinkhole attack, attackers compromise a node in a network to attract and intercept all traffic, claim unlimited and unconstrained capabilities which will be selected for forwarding all traffic in WSN often leading to data loss or delays in IoT systems.

Sleep Deprivation Attacks: This attack targets IoT devices' battery life by keeping them active for long periods, forcing them to deplete energy faster and disrupt operations.

Node Tampering: Physical accessing to IoT devices will allow attackers to tamper with hardware, leading to device manipulation or data extraction.

Node Injection: Attackers introduce a rogue or malicious node into the IoT network to capture sensitive data or disrupt normal communication between devices.

Brute Force Attack: A brute force attack will involve systematically trying all the possible combinations of passwords or encryption keys to gain illegal and unauthorized access to IoT devices or data.

Phishing Attack: Phishing uses deceptive and false emails or messages to con users into revealing sensitive information, such as login credentials, which can be used to compromise IoT systems.

Node Capture Attack: Attackers physically capture and manipulate a node to extract sensitive information such as encryption keys, enabling them to compromise the network. For example, capturing a sensor node in a smart grid can give access to energy consumption data.

Black Hole Attack: A malicious node sends fake route replies to attract data packets, then discards them instead of forwarding. For instance, this can disrupt communication in IoT-based smart transportation systems. Can send route replay messages to source node to receive packets from the sender node

Wormhole Attack: Two malicious nodes create a tunnel to transmit data between distant locations, bypassing normal routing. This can disrupt sensor networks by making data appear to travel shorter paths.

Sybil Attack: An attacker creates multiple fake identities (nodes) in a network to control operations and resources. For example, in a smart city network, Sybil nodes could overload routing paths or falsify traffic reports.

RFID Sniffing: Attackers use sniffing tools to intercept data transmitted between RFID tags and readers, exposing sensitive information like payment credentials or product details.

RFID Spoofing: Fake RFID tags mimic genuine ones to gain unauthorized access. For example, spoofing RFID access cards can bypass physical security in IoT-enabled buildings.

RFID Cloning: Attackers duplicate RFID tag information to create a clone, granting unauthorized access. For instance, cloning a toll RFID tag can allow vehicles to pass checkpoints without payment.

Encryption Attack: Attackers use techniques like timing or power analysis to crack encryption keys, exposing secure communication. This can compromise IoT devices like smart locks or medical devices.

Code Injection: Malicious code is injected into IoT systems to gain control. For example, injecting malicious scripts into a smart thermostat's firmware can allow an attacker to control home temperatures remotely.

Denial of Service (DoS): Overwhelming IoT devices with requests or traffic, making them unavailable to legitimate users. For instance, a smart surveillance system might be disabled during a burglary.

Node Jamming: A subset of DoS attacks where attackers emit radio noise or signals to interfere with IoT device communication. For example, jamming a smart doorbell's signals can prevent it from sending alerts.

- **RNG Tampering:** The attacker manipulates the random number generator, ensuring the adversary's back-off periods are significantly shorter than those chosen by legitimate nodes.
- **Back-Off Countdown Skipping:** A malicious attacker bypasses the entire random back-off countdown process.
- **CCA (Clear Channel Assessment) Exploitation:** The attacker modifies, reduces, or omits the CCA process, allowing them to access the channel more frequently and faster than legitimate network nodes.
- **Repeated Nonce Usage:** Through this attack, the adversary uses identical nonces to extract valuable information from ciphertext data.
- **Replay-Protection Bypass:** Attackers send frames with high sequence numbers to trick nodes into discarding legitimate frames with smaller sequence numbers.
- **False Acknowledgment (ACK) Attack:** The attacker sends a fraudulent acknowledgment with the correct sequence number, deceiving the sender into thinking the data was delivered successfully and preventing retransmissions.
- **Guaranteed Time Slot (GTS) Exploitation:** This attack exploits vulnerabilities in the GTS management mechanism to disrupt network functionality.
- **PANId Conflict Exploitation:** An attacker sends fake PANId conflict messages to the coordinator, exploiting the conflict resolution procedure to disrupt the network.

2.2 IOT security crimes

The widespread usage of IoT applications increased the risk of attacks that hackers can exploit. We will learn about a few most popular real-world crimes involving IoT.

The Mirai Botnet Attack: This was one of the largest Distributed Denial of Service attacks that turned IoT devices into hosts controlled by the hackers. This occurred in 2016 when the Mirai malware infected thousands of IoT devices, such as routers, IP cameras, and DVRs. The malware turned these compromised devices into bots, creating a massive botnet. The Mirai botnet was first identified when the attack started in 2016. The attacker's botnet was composed of over 600,000 infected IoT devices, including cameras, routers, and other devices affecting millions of people. Mirai primarily exploited weak or default passwords on IoT devices to gain access. Once compromised, the infected devices were used to flood targeted websites with overwhelming traffic, making them inaccessible. One of the largest Mirai-driven attacks was on **Dyn**, a major DNS provider, which resulted in widespread internet outages affecting sites like Twitter, Netflix, and Reddit. The Mirai botnet attack exposed critical vulnerabilities in IoT devices, particularly the lack of strong security practices like password protection and firmware updates. It underscored the need for stricter IoT security protocols to prevent such large-scale disruptions in the future.

The verkada hack: Verkada is a security company which manufactures security cameras and provides security services. In march 2021 hackers gained access to the live feeds of over 150,000 security cameras used by various institutions, including hospitals, schools, police departments, jails, and private companies like Tesla. These cameras were part of Verkada's cloud-based security system. The attackers reportedly exploited a "super admin" account with high-level access, using valid credentials that had been exposed online. This allowed them to infiltrate Verkada's internal systems and view real-time footage, including sensitive areas such as hospital ICU rooms, police station interrogation rooms, and prison cells. The Verkada hack raised major concerns about the security of cloud-based surveillance systems and the importance of properly managing access controls and credentials. It highlighted vulnerabilities in IoT ecosystems, particularly those with internet-connected devices like security cameras. This breach underscored the need for better security protocols, such as two-factor authentication and stronger access management, in cloud-based and IoT environments.

St. Jude Medical Implant Cardiac Devices Hack: refers to a major security vulnerability discovered in **2016** in cardiac devices manufactured by **St. Jude Medical** (now part of Abbott Laboratories). The vulnerability affected implantable cardiac devices, such as pacemakers and defibrillators, which were connected to a network using a transmitter to monitor and control the devices remotely.

Researchers from the cybersecurity firm **Medsec** identified that the devices and their communication systems had several security flaws, including insufficient encryption and weak authentication protocols. These vulnerabilities could potentially allow attackers to remotely control the devices, causing harmful alterations to critical settings, such as delivering inappropriate shocks to a patient's heart or depleting the battery prematurely. It also led to Intercept data transmitted from the devices, leading to privacy concerns as sensitive health information could be exposed. The U.S. Food and Drug Administration (FDA) confirmed the security risks in 2017, leading to recalls and software updates to address these vulnerabilities. This incident highlighted the significant risks associated with connected medical devices and the need for stronger security measures to protect both patient safety and data privacy in the healthcare IoT ecosystem. It was one of the earliest examples showing how medical IoT devices could be targeted in cyberattacks, raising awareness of cybersecurity in healthcare.

VPN FILTER MALWARE attack: The **VPNFilter malware attack** is a sophisticated cyberattack targeting network devices, particularly routers and network-attached storage (NAS) devices, often used in IoT environments. This malware, first discovered in 2018, is known for its advanced capabilities, persistence, and multi-stage architecture. The key features of this are it's multistage infection, data theft and monitoring, device destruction and control. It first establishes persistence by exploiting device vulnerabilities and downloading additional payloads. This stage survives device reboots, making it difficult to remove. It enables the malware's core functionality, including data interception, device control, and exfiltration. It also supports destructive capabilities, like bricking devices. Adds optional plugins to enhance functionality, such as packet sniffing, Modbus protocol exploitation (used in industrial systems), and communication obfuscation. VPNFilter can intercept and steal sensitive data, such as login credentials and other network traffic passing through compromised devices. The malware includes a "kill switch" that allows attackers to render

devices inoperable, potentially causing widespread disruption. The malware primarily targets consumer and small business-grade routers from brands like Linksys, MikroTik, Netgear, and TP-Link. It also affects some NAS devices. VPNFilter uses a decentralized C2(command and control) infrastructure, leveraging public websites like Photobucket or encrypted communications over the Tor network to receive commands. VPNFilter affected hundreds of thousands of devices globally and posed significant threats, particularly to IoT networks that rely on vulnerable routers. The malware's ability to perform industrial system attacks raised concerns about its potential use in critical infrastructure sabotage.

Tesla model X hack: The **Tesla Model X hack** refers to a security exploit discovered by researchers that demonstrated vulnerabilities in Tesla's keyless entry system, particularly in Bluetooth-based communication between the car and its key fob. The hack gained attention as it highlighted potential flaws in even advanced electric vehicles like Tesla's Model X. □ The attack involved exploiting vulnerabilities in the firmware update process of the Tesla key fob. Researchers discovered that the key fob firmware lacked sufficient security checks, allowing them to update it with malicious code. Using specialized hardware, attackers could communicate with the car from up to 5 meters away. By connecting to the car's Bluetooth module, they could impersonate the legitimate key fob and trick the vehicle into unlocking. □ The researchers demonstrated how attackers could bypass authentication and gain control over the car. Once access was established, the attacker could pair a new key fob with the car, enabling them to start the vehicle and drive it away. The hack required readily available hardware costing about \$300, such as a Raspberry Pi, a CAN shield, and an aftermarket key fob. This made the attack relatively inexpensive and accessible to technically skilled attackers. This hack highlighted weaknesses in keyless entry systems that rely on Bluetooth and other wireless technologies, which are increasingly used in modern vehicles. Tesla's ability to deploy OTA updates allowed the company to quickly patch the issue without requiring physical recalls.

STUXNET ATTACK: Stuxnet is one of the most infamous attacks on IoT systems, targeting the uranium enrichment facility in Natanz, Iran. The attack exploited vulnerabilities in Siemens Step7 software, which operated on Windows, to infiltrate and manipulate industrial programmable logic controllers (PLCs). This gave the attackers control over various industrial machines and access to critical operational data.

The first signs of issues at the facility emerged in 2010 when International Atomic Energy Agency (IAEA) inspectors noticed an unusually high failure rate in uranium enrichment centrifuges. Around the same time, multiple malicious files were detected on Iranian computer systems, including the Stuxnet worm.

While Iran has not disclosed the full impact of the attack, it is estimated that Stuxnet caused damage to 984 centrifuges, reducing enrichment efficiency by approximately 30%.

THE JEEP HACK: The **2015 Jeep hack** was a groundbreaking cybersecurity demonstration that exposed critical vulnerabilities in Internet of Things (IoT)-enabled vehicles, specifically in the Jeep Cherokee. It highlighted how hackers could exploit connected car systems to gain remote control over essential vehicle functions, posing

significant safety risks. The hack targeted the **Uconnect infotainment system**, an IoT component that connects the vehicle to the internet and enables features like navigation, entertainment, and remote diagnostics. The Uconnect system had an open cellular connection that allowed attackers to send commands remotely. Security researchers Charlie Miller and Chris Valasek exploited a vulnerability in Uconnect's software that lacked proper authentication for remote access. By using the vehicle's public IP address, the attackers could send malicious commands to the car's internal network (CAN bus). The researchers demonstrated full remote control over the vehicle while it was in motion, including adjusting climate control and windshield wipers, manipulating the radio and displaying unexpected images on the screen and taking over critical functions like the steering, braking, and engine acceleration under certain conditions. During the demonstration, the researchers intentionally caused a Jeep Cherokee to stop on a highway, showcasing the potential for catastrophic real-world consequences. Fiat Chrysler Automobiles (FCA) recalled **1.4 million vehicles** to address vulnerability, marking one of the first large-scale cybersecurity recalls in the automotive industry. The 2015 Jeep hack serves as a pivotal moment in IoT security, highlighting the need for robust safeguards in connected devices to ensure both digital and physical safety.

3 Solutions, Analysis and results

This section presents the solutions to the most common IOT security problems along with some of the primary concerns and challenges including some of the ones mentioned in the previous report.

I proposed and designed a model LAKE-ECC (Lightweight Authenticated Key Exchange over Elliptic Curve Cryptography), a session key establishment protocol designed specifically for resource-constrained IoT nodes. I added this last as per Prof Jay Kamlesh instruction

3.1 Solution for Iot security

Blockchain-Based Solutions

Blockchain provides a decentralized and tamper-resistant ledger, which can be used to secure IoT transactions, data exchanges, and authentication processes. Each IoT transaction can be recorded in a blockchain, ensuring immutability and transparency. Blockchain eliminates the need for a centralized authority, enhancing privacy and security for IoT systems. Smart contracts can also automate and enforce security policies in real-time. Blockchain-based solutions are particularly useful in environments like supply chain management and smart cities. A set of transactions are grouped into a single block and validated. These blocks are linked to form a chain of blocks forming blockchain. Each block consists of two parts, the first part represents transactions and the second part contains hash of the block and hash of previous block. The consensus process is executed by nodes in the network called miners. Common consensus algorithms include power of work (PoW), power of stake (Pos), and practical byzantine fault tolerance (PBFT) . These algorithms can be used to enable miners for adding a new block to the blockchain or deleting it. Ethereum and Bitcoin are the most popular public blockchains. In a blockchain-based IoT system, a new digital transaction is securely transformed into a cryptographically protected block. Miners compete to validate the transaction, after which it is timestamped and added to the blockchain in chronological order. When nodes accept a block, it is linked to the chain using the hash of the previously approved block.

The communication framework consists of peer-to-peer messaging, distributed data sharing, and autonomous coordination with devices. In this model:

- **Blockchain Nodes:** These are the network members and can be personal computers, enterprise servers, or cloud-based nodes.
- **Clients:** IoT devices act as clients and interact with nodes via APIs. Clients create transactions, which nodes process and store in the distributed ledger.

The distributed ledger can also store encryption keys to enhance confidentiality. For secure communication:

1. An IoT device sends an encrypted message using the public key of the intended recipient.
2. The message is stored in the blockchain network.
3. The sender requests the public key of the receiver from the ledger through its node.
4. Using the receiver's public key, the sender encrypts the message, ensuring that only the receiver can decrypt it using their private key.

Lightweight Cryptography-Based Solutions

Traditional cryptographic techniques can be resource-intensive for IoT devices, which often have limited processing power, memory, and battery life. **Lightweight cryptography** is designed specifically for IoT, offering encryption and authentication mechanisms that require fewer computational resources. These algorithms, such as **Lightweight Advanced Encryption Standard (AES)** and **PRESENT**, provide robust security without overwhelming IoT devices, making them ideal for securing communication, data storage, and access control in resource-constrained environments. Lightweight cryptographic algorithms can be divided into four main types which are block ciphers, stream ciphers, hash functions and elliptic curve cryptography. Block cypher execute one block at a time while stream cyphers execute test in byte and bit formats. ECC is a lightweight asymmetric cryptographic technique that provides good levels of security as rivest-shamir-adleman (RSA) algorithm with smaller key size.

Fog Computing-Based Solutions

Fog computing extends cloud services closer to the IoT devices by processing data at the edge of the network, rather than relying on distant cloud servers. This reduces latency and improves real-time decision-making for security. Fog nodes can perform security tasks like threat detection, encryption, and anomaly analysis locally, reducing the data exposed to potential threats in transit. Fog-based security solutions help in mitigating Distributed Denial of Service (DDoS) attacks and improve privacy by keeping sensitive data near its source. The fog architecture helps to reduce the amount of data exchanged between the IoT devices and the cloud infrastructure. It supports mobility, low latency, scalability and can be perfectly adapted into real-time or latency-sensitive IoT applications.

Software Defined Networking (SDN)-Based Solutions

Software Defined Networking (SDN) separates the control plane from the data plane, allowing for centralized control of network traffic. In IoT environments, SDN enables dynamic configuration of security policies across devices and networks. SDN controllers can monitor network traffic, detect anomalies, and apply security rules or quarantine compromised devices in real-time. SDN-based IoT security solutions provide better scalability, flexibility, and control over large, distributed IoT networks. . In SDN architecture, the network control operations like forwarding tables and ACL rules are handled by a SDN controller, but data forwarding is managed by the network elements. It is a very effective method of achieving security in IOT devices.

Machine Learning-Based Solutions

Machine Learning (ML), a rapidly advancing technology, has shown considerable promise in addressing IoT security issues. In this report we are going to examine in depth about a few applications. Machine learning (ML) is used to identify patterns and detect anomalies in IoT network behaviour. By analysing large datasets from IoT devices, ML algorithms can detect unusual patterns indicative of cyberattacks like Distributed Denial of Service (DDoS) or malware. ML-based solutions can be integrated into intrusion detection systems (IDS) to detect real-time threats and enhance predictive security. However, these solutions require

significant processing power, so they are often implemented in conjunction with fog or cloud computing to overcome resource limitations. Recent advancements have been made in the sun fields of Machine learning in deep learning, CNN and RNN which can be used to improve IOT security.

3.2 Related work:

Many different researches were proposed to provide and improve various security requirements in the field of IOT security. Several studies have explored various aspects of IoT security, including threat detection, secure communication protocols, authentication mechanisms, and privacy concerns.

One of the earliest comprehensive studies on IoT security challenges was conducted by Atzori et al. (2010), where the authors provided an overview of the IoT architecture and identified key security issues, such as data integrity, confidentiality, and authentication. The authors emphasized that resource-constrained devices and heterogeneous network architectures make it difficult to deploy traditional security mechanisms in IoT environments. In a more recent study, Sicari et al. (2015) provided an extensive survey on IoT security, discussing the main vulnerabilities across different layers of the IoT architecture and the need for context-aware security mechanisms.

One of the critical areas of IoT security is the protection of data in transit. In recent years, several studies have focused on encryption and secure communication protocols to safeguard IoT networks from attacks such as eavesdropping and data interception. Raza et al. (2013) presented a lightweight communication protocol for resource-constrained IoT devices based on the Datagram Transport Layer Security (DTLS) protocol. The authors demonstrated that DTLS can secure communication between IoT devices without imposing excessive computational overhead. Similarly, Babar et al. (2011) developed a framework for implementing security protocols tailored for low-power IoT devices, highlighting the need for energy-efficient cryptographic algorithms.

The use of blockchain technology for securing IoT systems has also gained momentum. In 2017, Dorri et al. proposed a blockchain-based solution to improve the privacy and security of IoT systems. Their approach focused on decentralized IoT networks, providing secure authentication and data integrity without relying on a centralized authority. The blockchain framework minimized attack surfaces and demonstrated the potential for secure IoT ecosystems.

Weak authentication mechanisms remain a major vulnerability in IoT devices. Many researchers have focused on developing lightweight, secure authentication protocols that can be deployed on resource-constrained IoT devices. For instance, Li et al. (2014) proposed a two-factor authentication scheme using user passwords and device-generated tokens for securing IoT networks. The study demonstrated that multi-factor authentication schemes provide better protection against common attacks, such as replay attacks and man-in-the-middle attacks.

A study by Perera et al. (2015) explored the use of biometrics for securing IoT devices in smart homes. The authors proposed a framework that uses voice recognition and facial recognition for user authentication, ensuring that unauthorized users cannot control IoT devices. While the proposed solution showed promise, it was limited to scenarios where biometric data could be easily captured.

Threat detection mechanisms, particularly those based on machine learning, have been widely studied to identify security anomalies in IoT networks. In 2019, Al-Garadi et al. conducted a comprehensive review of machine learning-based solutions for detecting cyberattacks in IoT environments. The authors noted that most machine learning models struggle with real-time threat detection in large-scale IoT deployments due to computational and energy constraints. Another significant contribution was made by Doshi et al. (2018), who proposed a lightweight intrusion detection system (IDS) for IoT devices. The IDS uses a combination of statistical analysis and machine learning techniques to detect abnormal traffic patterns indicative of a DDoS attack. Their study emphasized the need for real-time detection mechanisms that can operate efficiently with limited device resources.

Ashraf et al. presented a detailed analysis of the use of machine learning (ML) and deep learning (DL) techniques in Intrusion Detection Systems (IDS) tailored for IoT networks. Their study explored the IoT architecture, related protocols, vulnerabilities, and potential protocol-level threats. It reviewed various research efforts focusing on IDS methodologies and attack detection strategies for IoT. Additionally, the paper provided an overview of ML and DL approaches for IoT IDS and highlighted datasets relevant to IoT security research. The authors concluded by identifying persistent challenges, emphasizing the need for further improvements in IDS solutions for IoT environments.

Ahmad and Alsmadi [17] conducted a comprehensive review of emerging trends in applying machine learning (ML) techniques for securing IoT environments. Their study synthesized current research from 2019 to 2020, focusing on the intersection of IoT, ML, and cybersecurity. They formulated six research questions targeting IoT security vulnerabilities, large-scale attack types, and the role of ML and deep learning (DL) in enhancing intrusion detection. The review identified significant advancements, particularly in defending against Distributed Denial of Service (DDoS) and botnet attacks. While ML and DL outperformed traditional detection methods, detecting zero-day attacks remains a major challenge. The study provided valuable insights into methodologies, performance evaluations, and future research directions for developing more robust intrusion detection systems.

Hossain et al. [15] explored ML and DL applications in enhancing IoT security and privacy. They discussed key security challenges, common attack vectors, and evolving defence strategies within the IoT ecosystem. The authors highlighted the limitations of conventional ML models and emphasized the potential of DL and Deep Reinforcement Learning (DRL) to improve detection accuracy and resilience. To address existing gaps, they recommended combining innovative learning techniques with advanced data visualization methods for more effective threat detection and interpretation.

Liang et al. [9] examined the role of ML in strengthening cyber-physical system (CPS) and IoT security while addressing associated challenges. They discussed the advantages of using ML in intrusion detection systems (IDS) and its application in CPS but also pointed out various vulnerabilities throughout the ML lifecycle, from data collection to implementation.

Additionally, they raised concerns about the potential misuse of ML models for malicious purposes, suggesting practical countermeasures to mitigate such risks.

Chaabouni et al. [10] conducted a detailed review of network intrusion detection systems (NIDS) tailored for IoT environments, focusing on ML-based approaches. Their work encompassed various NIDS datasets, implementation frameworks, and open-source sniffing tools. They examined NIDS architecture, deployment models, and key methodologies while comparing traditional and ML-powered defence mechanisms. The review highlighted state-of-the-art ML algorithms with high detection accuracy and low false-positive rates. It also identified promising future research directions in ML-based NIDS development for IoT systems.

Anthi et al. designed a three-layer IDS using supervised ML. The system profiles IoT devices, performs binary classification to differentiate between normal and malicious activity, and conducts multi-class classification to identify specific attack types. After gathering empirical data for training and testing, the system was evaluated using several classifiers. The J48 algorithm outperformed others, achieving classification accuracies of 96.2%, 90.0%, and 98.0% across the three layers. These results underscored the model's potential for automating IDS tasks.

Alqahtani et al. proposed an IDS incorporating various ML classifiers, including Random Forest, Bayesian Network, Decision Trees, Artificial Neural Networks, and Naive Bayes. The KDD'99 dataset was used for training and testing, with evaluation metrics such as precision, recall, F1-score, and accuracy. Among the tested models, Random Forest delivered the best performance, achieving a 94% accuracy, 99% precision, 93% recall, and a 97% F1-score.

Sarker et al. developed "IntruDTree," an ML-based IDS that prioritizes key security features to build a decision-tree-based classification model. The system was tested on a specialized dataset, enabling anomaly-based binary classification. Evaluation metrics, including precision, recall, F1-score, and accuracy, showed consistent performance, with the model scoring 98% across all parameters.

Rahman et al. proposed parallel ML-based IDS models using both distributed and semi-distributed architectures to reduce latency in centralized IDS frameworks. The semi-distributed model processes feature selection at the edge level and classification in the fog layer, while the distributed model performs both processes at the edge. Evaluations conducted with the AWID dataset demonstrated promising results, with the semi-distributed model achieving 99.97% accuracy and the distributed model showing significant computational efficiency, requiring only 73.52% CPU time for model training.

Ferrag et al. introduced a hierarchical IDS model, RDTIDS, that combines three classifiers: JRip, REP Tree, and Forest PA. Two classifiers process raw data for binary and multi-class classification, while the third classifier integrates these outputs for enhanced multi-class classification. Trained and tested on CICIDS2017 and Bot-IoT datasets, the system effectively detected major attack types, achieving over 96% accuracy and a detection rate above 94%.

Zhang et al. proposed a multi-dimensional feature fusion stacking ensemble mechanism (MFFSEM) for network intrusion detection. Their approach addresses the limitations of

traditional ML methods by combining Decision Tree and Random Forest classifiers. The system was tested using datasets such as CIC-IDS2017, NSL-KDD, KDD Cup 99, and UNSW-NB15, achieving exceptional accuracy and recall rates, particularly with the CIC-IDS2017 dataset, where it reached 99.95%.

Alduailij et al. developed a DDoS detection system for cloud environments using the CICIDS 2017 and 2019 datasets. Their approach employed feature selection techniques like Random Forest Feature Importance (RFFI) and Mutual Information (MI) and used classifiers such as Weighted Voting Ensemble (WVE), Gradient Boosting (GB), K-Nearest Neighbours (K-NN), Random Forest (RF), and Logistic Regression (LR). Their model achieved high accuracy, reaching 99.997%, surpassing other existing techniques.

Gu et al. proposed an IDS model that enhances data quality through an SVM integrated with Naive Bayes feature embedding. Two versions were developed: NB-SVM, which uses transformed features only, and NB-SVM2, which combines transformed and original features. Tested on datasets including NSL-KDD, CICIDS2017, UNSW-NB15, and Kyoto 2006+, the system demonstrated excellent accuracy and recall rates, exceeding 99%.

Hu et al. introduced a novel IDS framework using Multiple Kernel Clustering (MKC) to address issues of data diversity and missing attributes. By estimating missing values through data similarity analysis, they generated a robust kernel matrix to improve classification accuracy. Tests on datasets like UNSW-NB15, NSL-KDD, and AWID showed superior results, with the system achieving 95.60% accuracy on the AWID dataset.

Panigrahi et al. proposed a signature-based IDS utilizing Multi-Objective Evolutionary Feature Selection (MOEFS) for feature selection and hybrid classification methods involving Decision Tables and Naive Bayes. The system, trained on the CICIDS2017 dataset, effectively detected various attacks, including botnets, DDoS attacks, and web-based intrusions. Its evaluation metrics indicated high performance, with recall, accuracy, and precision scores of 96.80%, 96.70%, and 97.40%, respectively.

Otoum et al. introduced a deep learning-based intrusion detection framework aimed at improving the accuracy of IoT attack detection. Traditional Intrusion Detection Systems (IDS) often face limitations such as inefficient feature selection and poor dataset management. To address these issues, their framework integrates the Spider Monkey Optimization (SMO) algorithm for optimal feature selection and a Stacked-Deep Polynomial Network (SDPN) for classifying data anomalies. The proposed DL-IDS framework was tested using the NSL-KDD dataset, achieving a remarkable accuracy of 99.02%.

Similarly, Ge et al. developed a deep learning-oriented IDS leveraging the Bot-IoT dataset for both training and testing. Their system employed a Feed-Forward Neural Network (FNN) for binary and multi-class attack classification, including reconnaissance, information theft, DoS, and DDoS attacks. The system's performance was assessed using metrics such as recall, precision, accuracy, and the F1 score, with results exceeding 98% across all parameters, demonstrating high efficacy in attack detection.

We also reviewed some popular models like zero trust model and digital twins. The **Zero Trust Model** is a security framework that operates under the principle of "never trust, always

verify." This model challenges the traditional security paradigms that assume trust based on network location. In the Zero Trust approach, every access request is treated as though it originates from an untrusted network, regardless of whether it comes from inside or outside the organization's perimeter. Every user, device, and application attempting to access resources must be authenticated and authorized before access is granted. This often involves multi-factor authentication (MFA) and continuous verification throughout the session. The model operates under the assumption that breaches can and will occur. Therefore, organizations need to have incident response and containment strategies in place, ensuring that any breach is swiftly contained. This is gaining popularity in IOT security

Digital Twins refer to virtual representations of physical entities, systems, or processes that serve as real-time digital counterparts. They leverage data from sensors and IoT devices to simulate, predict, and analyze the performance of their physical counterparts, allowing for improved decision-making, monitoring, and optimization throughout the lifecycle of the entity they represent. Physical entity is the actual physical object or system, such as a machine, vehicle, building, or even an entire factory. The digital twin consists of a virtual model that mimics the characteristics the physical entity. This model is continually updated with real-time data. Sensors and IoT devices collect data from the physical entity, which is then transmitted to the digital twin. Digital twins provide real-time insights and predictive analytics, enabling organizations to make informed decisions based on accurate data. But integrating data from various sources and ensuring data quality can be challenging.

3.3 ARTIFICIAL INTELLIGENCE and MACHINE LEARNING IN IOT SECURITY

Machine learning (ML) is transforming IoT network security by enabling real-time analysis of network traffic to identify potential security threats. By continuously examining data patterns from connected devices, ML algorithms can detect unusual activities that may indicate cyberattacks. This section explores the latest trends in IoT security, highlighting practical examples and case studies to demonstrate how ML techniques are applied in real-world applications.

Anomaly Detection Systems

Machine learning (ML) plays a crucial role in identifying anomalies in IoT networks. These models provide real-time monitoring of network traffic, detecting unusual patterns that may signal security breaches, and adapting to emerging threats based on historical data. Unlike traditional systems, ML's ability to learn and evolve enhances its effectiveness, enabling it to identify new threats as they arise. This dynamic approach allows for tailored security protocols that suit the unique needs of each IoT network, offering a robust and responsive defence against diverse cyberattacks.

Predictive Maintenance in Industrial IoT

In industrial settings, ML algorithms are increasingly utilized for predictive maintenance of IoT devices. By analysing extensive sensor data, such as temperature, vibration, and pressure, these models can anticipate potential equipment failures before they happen. This proactive strategy minimizes downtime and optimizes performance, leveraging real-time data to address issues pre-emptively. The continuous monitoring of machinery by IoT devices and

the insights provided by ML algorithms ensure operational efficiency and reduce the risk of unexpected failures.

Smart Home Security Systems

ML is revolutionizing the security of smart homes by offering advanced and adaptive solutions. A notable application is facial recognition, where ML-enabled systems dynamically identify residents and regular visitors, eliminating the need for static passcodes or keys. Over time, these systems refine their accuracy by learning from diverse interactions. Additionally, ML-based security systems monitor household routines to detect anomalies, such as unusual movement patterns or odd entry times, alerting homeowners promptly. This technology is especially useful for ensuring the safety of elderly family members or securing homes during absences.

Automotive Security

The integration of communication technologies in connected vehicles has enhanced safety, efficiency, and convenience. Vehicles communicate with other cars (V2V), infrastructure (V2I), and devices (V2X), creating an interconnected transportation ecosystem. ML significantly improves security by identifying potential threats and predicting vehicle faults before they occur, based on historical data patterns. This proactive maintenance reduces risks and enhances reliability. However, challenges like safeguarding data privacy, preventing ML model manipulation, and maintaining updated systems remain critical to ensuring robust automotive security.

Healthcare IoT Security

IoT devices in healthcare, such as wearable monitors and connected medical equipment, manage vast amounts of sensitive patient data, requiring strong security measures. ML enhances data security by monitoring transmissions between devices and central servers, ensuring encryption standards are upheld and detecting potential breaches in real time. Automated threat responses, such as restricting access or notifying personnel upon suspicious activity, reduce the reliance on manual oversight. These measures ensure patient data confidentiality while maintaining the integrity of healthcare IoT systems.

Supply Chain Monitoring

ML models enhance supply chain security by monitoring the integrity of goods, particularly in industries handling sensitive products. By analysing data from IoT devices and sensors attached to goods, ML can detect signs of tampering, environmental deviations, or unauthorized access throughout the supply chain. These insights improve reliability and ensure products maintain their intended condition during transit. This level of monitoring strengthens supply chain security, reducing risks associated with compromised goods.

INTRUSION DETECTION SYSTEMS

An Intrusion Detection System (IDS) is a set of devices or software that helps organizations protect against network attacks and malicious behavior. It detects anomalies in network traffic or logs and sends alerts to the system's management unit if any abnormalities are found. IDS uses proactive security defense technology to identify and respond to intrusion behavior, taking measures to prevent it and collect evidence.

Intrusion Detection Systems (IDS) typically follow a standard structure comprising three key components: a data collection module, an analysis module, and an attack reporting mechanism. The data collection module gathers input from various IoT system components, enabling the identification of normal interaction patterns and early detection of malicious behaviour. The analysis module processes this data to identify attacks, with machine learning (ML) and deep learning (DL) methods being particularly effective for examining interactions within IoT environments. These methods excel at recognizing both benign and anomalous behaviour and have the advantage of predicting novel attacks, as they can intelligently learn from existing legitimate data samples.

The design of IDS varies based on several critical factors:

- **Detection of the Methods:** Can utilize signature-based, anomaly-based, or hybrid approaches.
- **Architecture IDSs:** May be centralized or distributed.
- **Data Sources:** Can rely on host-based, network-based, or hybrid data inputs.
- **Time of Detection in it:** Detection may occur in real-time (online) or after the fact (offline).
- **Environment in which it thrives:** Applicable to wired, wireless, or ad-hoc networks.

Signature-Based Detection Techniques

Signature-based detection relies on a repository of known attack signatures to compare against network traffic or system actions. When a match is identified, an alert is triggered. While effective for detecting known attacks, this method struggles with zero-day threats and mutations of existing attacks. To address these limitations, researchers have explored Artificial Immune System (AIS) models that mimic immune cell behaviour to classify packets as normal or malicious. However, applying such techniques in resource-constrained IoT environments remains challenging. Other solutions include using external machines or optimizing signature-matching algorithms to reduce computational demands, such as leveraging open-source tools like Snort and Clam AV for signature repositories.

Anomaly-Based Detection Techniques

Anomaly-based techniques detect threats by establishing a baseline profile of normal system behaviour and flagging any significant deviations. This approach is more effective at identifying novel attacks compared to signature-based methods. However, creating an accurate baseline is challenging and often leads to higher false positive rates. Machine learning (ML) is frequently used to build these profiles, but the computational and energy demands of ML models pose challenges in IoT environments with limited resources.

Specification-Based Detection Techniques

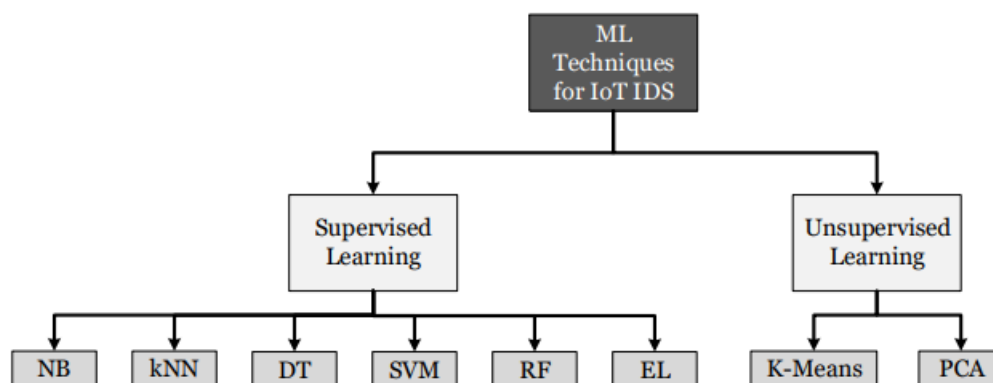
Specification-based techniques also rely on profiling normal system behaviour but differ from anomaly-based methods in how the profile is created. Instead of using ML, human experts manually define a set of rules and acceptable deviations. This reduces false positives compared to anomaly-based approaches but introduces issues of adaptability and the risk of specification errors. Additionally, these techniques lack the ability to learn and adapt to changing environments.

Hybrid-Based Detection Techniques

Hybrid detection methods combine elements of signature-based, anomaly-based, and specification-based techniques to leverage their strengths while mitigating their weaknesses. For example, the SVELTE system was designed for IP-connected IoT networks using a combination of signature and anomaly detection. This approach balances the storage requirements of signature-based methods with the computational demands of anomaly-based techniques, optimizing overall system performance for IoT environments.

MACHINE LEARNING BASED TECHNIQUES FOR IDS

All type of IDS models depend on a machine learning / artificial intelligence algorithm. We are going to discuss different ML techniques used for IoT environment based IDSs along with their pros and cons.



Naive Bayes Classifier

The Naive Bayes classifier applies the important Bayes' theorem to find the probability of an event based on prior occurrences of similar events. It is widely used in supervised learning to distinguish between normal and abnormal behaviours in network traffic. This algorithm

calculates posterior probabilities using independent features such as protocol type, latency, or status flags to classify traffic as normal or anomalous. Known for its simplicity and efficiency, Naive Bayes requires minimal training data and supports both binary and multi-label classifications. However, it fails to take into account interdependence between features for classification purposes, which affect its accuracy. Despite this limitation, it remains a popular choice for IDS implementations.

K-Nearest Neighbour (KNN)

The K-Nearest Neighbors (KNN) algorithm is a non-parametric method that operates without requiring predefined parameters. It classifies data based on the proximity of a given instance to its neighboring data points. KNN uses the Euclidean distance to evaluate similarity and assigns a class to the new data instance based on the majority class among its nearest neighbours.

In this classification approach, classes are represented by observed instances, such as green squares indicating normal behaviour and red triangles indicating abnormal behaviour. A new, unknown instance, such as a blue hexagon, is classified by determining its closest neighbours and their majority class. For instance, if $k=1$, the new instance will be assigned the class of its single nearest neighbour. If $k=3$, the classification might change based on the majority class of the three nearest neighbours. This underscores the importance of optimizing the parameter k through testing, as it significantly influences the algorithm's performance.

KNN has demonstrated effectiveness in detecting specific IoT network attacks, such as User-to-Root (U2R) and Remote-to-Local (R2L) attacks. While KNN's simplicity and intuitive design make it appealing, challenges remain in selecting the optimal k value and addressing missing nodes, both of which can increase computational costs and impact accuracy.

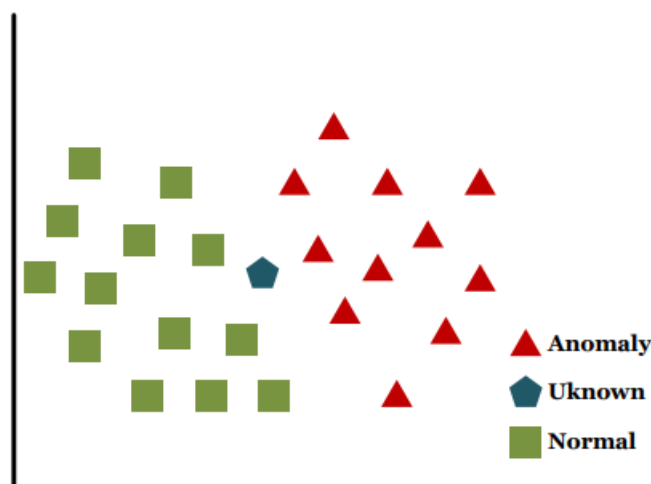


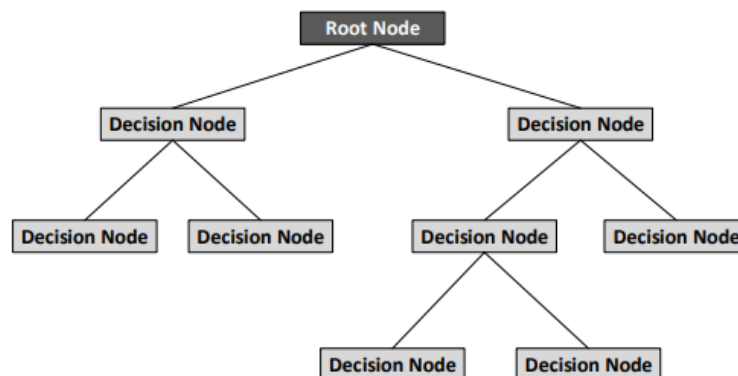
Figure 11. K-Nearest Neighbor (KNN) classification principle.

Decision Trees (DTs)

Decision Trees are a classification and decision-making tool that organizes data features into a hierarchical tree structure. Decision Trees will do by extracting features of the samples in a dataset and then organizing an ordered tree based on the index of a feature. Each node in the tree represents a feature, and the branches represent possible values for that feature. The root node is selected based on datasets metrics like the Gini index or Information Gain, which determine the feature that best splits the dataset into distinct groups.

The DT construction process involves two phases: **induction** and **inference**. During induction, nodes and branches are added to the tree by selecting features that minimize overlap between different classes in the training data. This process continues until the tree's leaves are defined and each represents a specific class. In the inference phase, new data instances are classified by tracing their features through the tree until they reach a matching leaf node.

In intrusion detection, DTs have been applied successfully, such as detecting Distributed Denial of Service (DDoS) attacks by analysing network traffic to identify malicious sources. However, their application in IoT environments may face challenges like high storage requirements and computational complexity, which should be considered.

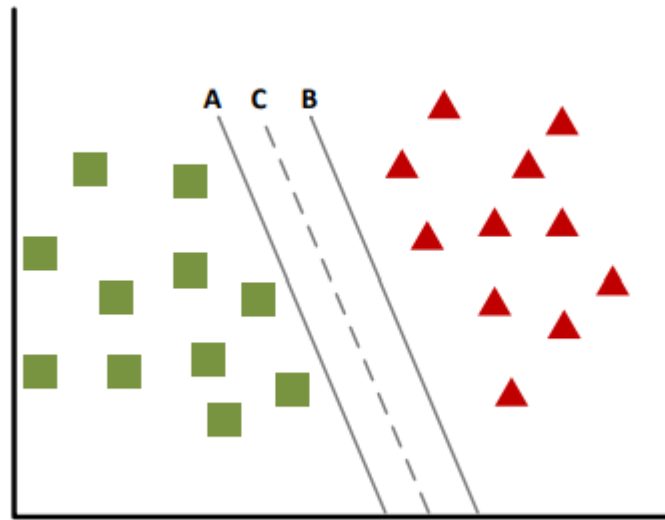


Support Vector Machines (SVMs)

Support Vector Machines are classifiers that separate data into distinct classes by creating a hyperplane in the feature space. This hyperplane is strategically placed to maximize the margin between the closest data points of different classes. SVMs are especially effective when dealing with problems that involve large feature sets but limited data samples, making them ideal for scenarios like anomaly detection.

SVMs are widely used in real-time applications, including anomaly driven intrusion detection in IoT systems. They are scalable and efficient, capable of handling tasks like online learning and dynamic traffic classification. For instance, the optimized SVM-based "Sec-IoV" model has been proposed for detecting anomalous traffic jams in vehicle to vehicle (V2V) communication within Internet of the Vehicles (Ivo) networks.

Additionally, SVM-based Intrusion Detection Systems (IDSs) did show higher accuracy compared to other machine learning algorithms such as Decision Trees, SVMs, Naive Bayes (NB), and Random Forests. However, selecting the optimal kernel function—critical for classifying data that is not non linearly and linearly separable—remains a key challenge for achieving efficient and fast classification.

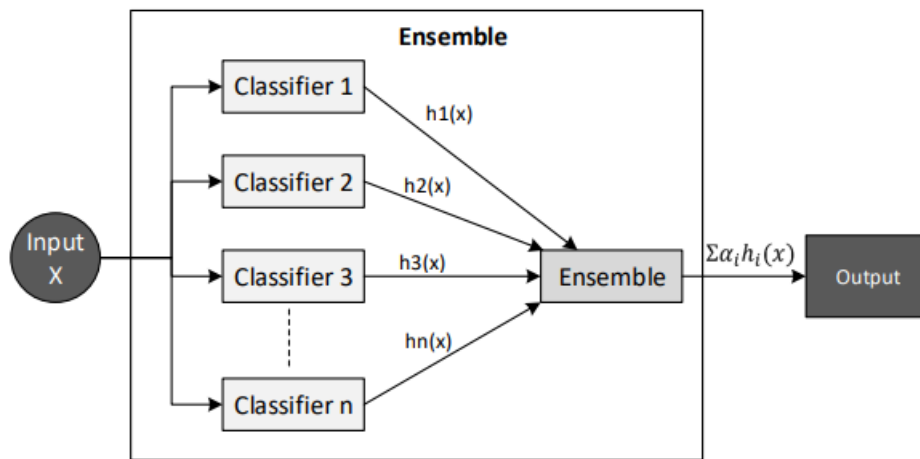


The Ensemble Learning (EL)

Ensemble Learning enhances classification accuracy by combining the outputs of multiple classifiers, either homogeneous or heterogeneous, to generate a majority vote for decision-making. This approach leverages the strengths of individual classifiers, reducing variance and mitigating overfitting, making it particularly effective for generalized applications where no single machine learning (ML) algorithm provides a universal solution.

EL methods have proven effective in intrusion detection systems (IDS) by combining classifiers to achieve more accurate results than individual models. However, this improved accuracy comes with the trade-off of higher time complexity because of the simultaneous use of multiple and many classifiers.

In resource-constrained environments like IoT, lightweight EL frameworks have been proposed for real-time anomaly detection, demonstrating better performance than standalone classifiers. This adaptability makes EL a robust option for IoT security applications, balancing accuracy and computational efficiency.



Random Forest (RF)

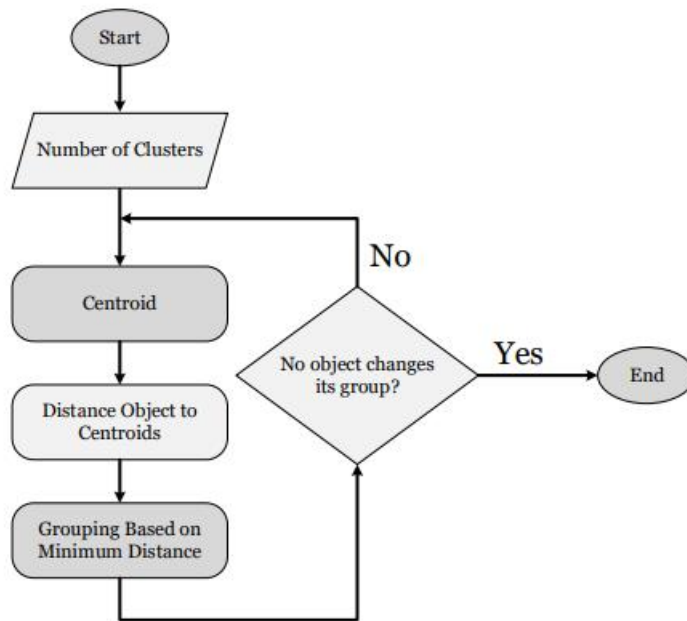
Random Forest is the supervised machine learning algorithm that incorporates multiple decision trees (DTs) to deliver accurate and error proof classification outcomes. Unlike individual DTs, which build a single ruleset during training, RF constructs multiple rule subsets from its member DTs and aggregates their outputs through majority voting. This approach increases robustness, reduces overfitting, and eliminates the need for manual feature selection, making RF highly effective for classification tasks.

Studies have shown RF to be particularly suitable for mainly anomaly and intrusion detection in IoT networks due to its efficiency and accuracy. Compared to algorithms like SVMs and K-Nearest Neighbours (KNN), Artificial Neural Network ANN, and Support Vector Machines SVMs, RF has demonstrated superior performance in detecting Distributed Denial-of-Service (DDoS) attack of IoT environments, requiring few input features and bypassing the intensive computations needed for real-time IDS operations.

k-Means Clustering

k-Means is an unsupervised learning algorithm that organizes data into k distinct clusters based on their features. Each data point is assigned to the cluster with the closest centroid, which is computed using the squared Euclidean distance. After assigning points, the centroids are updated by calculating the mean of the data points in each cluster. This process repeats iteratively until the clusters no longer change.

One challenge with k-Means is selecting the appropriate value of k , as well as the assumption that data is uniformly distributed across all clusters, which can limit the algorithm's effectiveness in certain scenarios. Despite these limitations, k-Means has proven useful in anomaly detection by identifying similarities in features. Some studies also suggest combining k-Means with other techniques, such as decision trees, to enhance anomaly detection in IoT networks.



Principal Component Analysis (PCA)

Principal multiple Component Analysis is not a direct anomaly detection algorithm but is widely used for feature selection and dimensionality reduction in large datasets. PCA reduces the number of features while retaining essential information, enabling more efficient processing by machine learning classifiers.

In IoT networks, PCA has been successfully combined with classifiers to enhance anomaly detection by simplifying large datasets. This integration enables improved accuracy and efficiency, making PCA a valuable preprocessing step in intrusion detection systems.

Machine Learning Models and Optimization Algorithms for Intrusion Detection Systems (IDS)

Gradient Boosting

Gradient Boosting also called GB is the most important ensemble learning technique designed to combine several weak models to form a competitive predictive model. The method sequentially trains each weak learner by focusing on the errors made by its predecessor, reducing the overall prediction error. Since GB requires labelled data for training, it is considered a mainly supervised model learning approach suitable for tasks such as classification and regression. In IDS research, the GB algorithm has been implemented for classification tasks, where it demonstrated exceptional performance, achieving accuracy levels of 100% and above 98% in various evaluation scenarios. This highlights its effectiveness in identifying complex patterns and detecting cyber threats in network environments.

LightGBM

Light Gradient Boosting Machine, developed by Microsoft, is the open-source gradient enhancing and boosting framework designed for high performance. It builds on traditional gradient boosting techniques while incorporating optimizations that enhance speed, memory efficiency, and scalability. Key improvements include leaf-wise tree growth, enhanced entropy, Gradient-Based One-Side Sampling also called (GOSS), and Exclusive Feature Bundling also called (EFB). Researchers have applied Light GBM alongside Particle Swarm Optimization (also called PSO) for mostly features extraction and dimensionality reduction, helping reduce dataset size for improved processing efficiency.

AdaBoost

Adaptive Boosting (AdaBoost) is a supervised ensemble learning algorithm that strengthens weak classifiers by training them iteratively on reweighted training data. After each iteration, the model increases the weights of misclassified samples, prompting the next classifier to focus on challenging instances. The final model combines all weak classifiers through weighted voting. In IDS research, AdaBoost has been used in distributed classification systems for detecting cyberattacks in IoT networks, achieving high precision. It has also been combined with fuzzy decision trees for adaptive learning in environments with concept drift, improving accuracy in real network traffic scenarios.

Optimization Algorithms for IDS Development

Optimization algorithms play a critical role in improving IDS models by selecting relevant features and tuning model parameters. Several popular algorithms are inspired by animal behaviour and social interactions, making them highly effective for machine learning tasks like classification, clustering, and regression.

1. Particle Swarm Optimization also called (PSO)

PSO is the population-based aggro optimization technique inspired by collective movement of birds or fish. It searches for optimal solutions by simulating particles moving across a search space, where one particle represents each potential question and solution. PSO has been successfully applied in IDS for feature selection and classification. For instance, researchers have used PSO with LightGBM to balance large-scale datasets, achieving superior accuracy compared to other techniques. PSO has also been combined with Grey Wolf Optimization (GWO) for multi-class classification tasks, demonstrating high accuracy across multiple datasets.

2. Greys Wolf Optimization (or GWO)

Inspired by the hunting behaviour of grey wolves, GWO mimics the hierarchical structure of wolf packs during hunting. Each wolf represents a possible solution, with the algorithm updating the wolves' positions based on the best-performing solutions. GWO has been used in IDS for feature selection, often in combination with PSO to create hybrid models. This combination has proven effective in enhancing feature subset selection, boosting model performance in classification tasks.

3. Spider Monkey Optimization (SMO)

SMO is based on the foraging behaviour and social coordination of spider monkeys. The algorithm organizes individuals into groups that collaborate during food searches, following the most successful monkey's strategy. In IDS research, SMO has been used for feature selection before applying deep learning classifiers. Studies using the NSL-KDD dataset have reported promising results, achieving high accuracy in detecting network intrusions.

These advanced machine learning models and optimization algorithms continue to play a pivotal role in developing efficient, accurate, and adaptive IDS systems for securing IoT networks.

Table showing various ML methods

ML Method	Attack Types Handled	Pros	Cons
KB	HTTP attack (Buffer will overflow, Shell attack), DoS and R2L Probe, R2L	Requires minimal samples for training - Capable of handling both binary and multi-label classification - Resistant to irrelevant features	Does not account for feature interdependencies, which impacts accuracy
KNN	U2R, R2L, Flooding attack, DoS, R2L, DDoS	- Simple to use	- Choosing the optimal k value and managing missing nodes can be difficult

SVM	Scan, DDoS (TCP AND R2L UDP flood), Smurf, ports weeping	- Highly scalable, suitable for real-time anomaly detection - Works well with large datasets containing many features - Efficient in terms of storage and memory use	- Selecting an optimal kernel for non-linearly separable data is challenging - Models can be hard to understand and interpret
EL	DoS, Probe, R2L, U2R attacks	- Resistant to overfitting - Outperforms individual classifiers - Reduces variance	- Higher time complexity due to parallel execution of multiple classifiers
RF	DoS, U2R, Probe, R2L, U2R	Provides robust, accurate results resistant to overfitting - Does not require extensive feature selection	- May be impractical for real-time applications involving large datasets
K-Means	DoS, U2R, Probe, R2L, U2R	- Will not require labeled data	- Less effective than supervised learning methods, especially for detecting known attacks
PCA	Used in multiple combinations with other ML/dl methods	- Ideal for large datasets, reduces dimensionality while preserving essential information - Simplifies the data	Not an anomaly detection method on its own; must be used alongside other ML methods to build a security model

Advanced Deep Learning Techniques for IDS models

Deep Learning techniques excel in handling large datasets and have demonstrated superior performance compared to traditional machine learning (ML) algorithms. This advantage makes DL particularly suitable for IoT security applications, where environments generate vast amounts of diverse data. DL is adept at automatically modelling complex feature sets from sample data, enhancing its relevance in IoT scenarios.

One notable benefit of DL is its capacity to facilitate deep linking within IoT networks, enabling automated interactions among IoT systems without human involvement. This automation supports collaborative functions and streamlines operations in connected environments.

DL, as a subset of ML, leverages deep architectures with many vector and non linear layers to extract hierarchical features representations. The layers process and transform data into abstract patterns, enabling advanced detection capabilities. DL can be applied in various modes:

1. **Generative Mode (Unsupervised Learning):** Focuses on identifying underlying patterns and structures within data.
2. **Discriminative Mode (Supervised Learning):** Aims at classification and prediction tasks by leveraging labelled data.
3. **Hybrid Mode:** Combines generative and discriminative approaches to achieve a balance between feature learning and classification.

The flexibility and scalability of DL make it a powerful tool for IoT-based intrusion and anomaly detection systems (IDSs), offering robust solutions for abstraction, pattern recognition, and anomaly detection in complex environments. Here multiple big DL based methods are used for designing an IDS are thoroughly discussed.

Recurrent Neural Networks (RNNs)

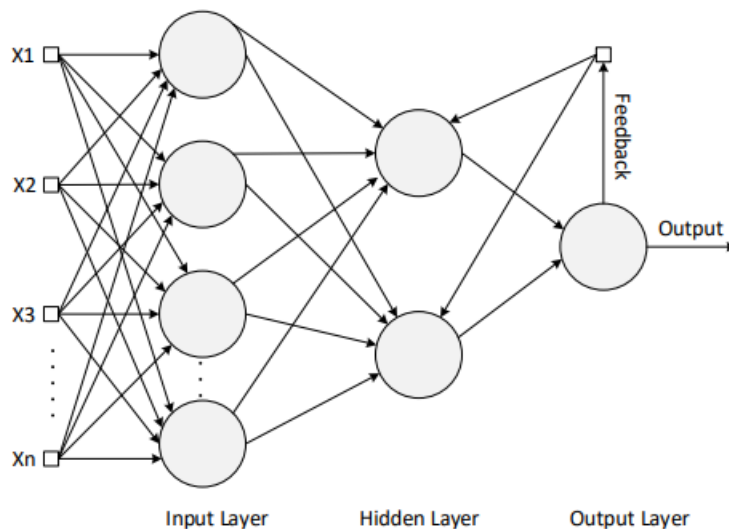
RNNs are discriminative deep learning algorithms designed specifically for environments where data is processed sequentially. Unlike conventional neural networks, the output in RNNs depends on backpropagation rather than forward propagation. A unique aspect of RNNs is the incorporation of a temporal layer, enabling them to analyse sequential data and learn multi-dimensional variations within the hidden units of recurrent components. These hidden units are dynamically modified based on the data the network encounters, leading to continuous updates that reflect the current state of the neural network.

RNNs function by predicting succeeding hidden states from prior states, leveraging their ability to trigger a previously hidden state for subsequent processing. For instance, outputs from neurons are fed back as input to neurons in earlier layers, creating a feedback loop essential for sequential data analysis.

IoT environments, known for generating extensive sequential data like network traffic flows, make RNNs highly applicable for security applications, particularly for network intrusion detection. Studies have shown RNNs effectively analyse network traffic behaviour, yielding promising results for detecting time-series-based threats. Additionally, research proposed a

multi-layered RNN-based intrusion detection system (IDS) with cascaded filtering stages, trained to detect common IoT-targeted attacks like R2L, DoS, U2R, and Probe.

A specialized RNN variant, Long Short-Term Memory (LSTM) networks, is particularly adept at persisting information or "cell states" for later use. This makes LSTM networks ideal for analysing temporal data with evolving patterns over time, addressing challenges related to anomaly detection in time-series datasets. Various forms of RNNs, including LSTMs, have been successfully employed in IoT intrusion detection systems. While RNNs demonstrate remarkable potential in predicting time-series data, challenges remain in detecting anomalous traffic effectively using these predictions.



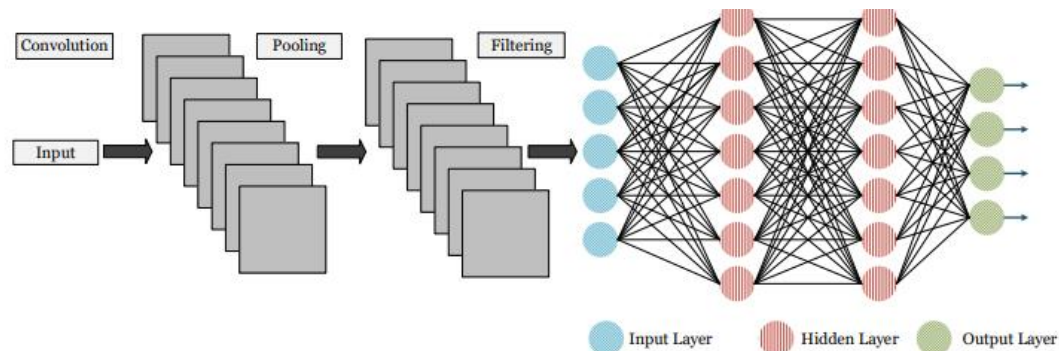
Convolutional Neural Networks (CNNs)

CNNs are a category of deep learning methods and algorithms designed to efficiently process and extract features from data. Unlike traditional artificial neural networks, CNNs minimize computational requirements by employing sparse interactions, parameter sharing, and equivariant representations. These features make CNNs more scalable and faster to train.

The structure of a CNN typically includes three types of layers: convolutional layer, pooling middle layer, and activation. Convolutional layers apply filters or kernels via the input data, extracting meaningful features. The Pooling layers then downsize the feature maps to reduce computational load and emphasize the most significant features. Two common pooling methods are max pooling, which selects the available maximum value from a cluster, and average pooling, which calculates the cluster's mean value. Activation layers apply non-linear transformations to improve the network's ability to model complex patterns.

CNNs excel at extracting features from raw data, making them suitable for tasks requiring high-efficiency feature extraction. However, their computational demands can pose challenges for resource-constrained IoT devices. To address this, distributed architectures are often employed, where lightweight versions of CNNs are implemented on devices, while more complex computations are offloaded to the cloud.

Research has shown that CNNs can effectively detect network anomalies and malware in IoT environments. Hybrid models combining CNNs with optimization techniques have demonstrated superior accuracy and detection rates compared to traditional IDS methods, making CNNs a valuable tool in IoT security.



Deep Autoencoders (AEs)

Deep Autoencoders are sophisticated unsupervised learning algorithms designed from to recreate their inputs at the outputs. This is achieved through two main components: the encoder function, which converts input data into a latent code representation, and the decoder function, which reconstructs the input from this code. A critical aspect of AE training is minimizing reconstruction errors to ensure accurate reproduction of input data.

AEs are often used for feature extraction, enabling the identification of significant patterns in datasets. However, their application can be limited by the need for significant computational power. In security contexts, AEs have been employed to detect network-based malware, demonstrating higher accuracy than traditional machine learning models like SVM and KNN.

An example of their application in IoT security is an online lightweight intrusion detection system (IDS) based on an ensemble of deep autoencoders. This approach has shown enhanced accuracy in anomaly detection compared to other deep and machine learning methods

Restricted and Boltzmann Machines (RBMs)

RBM is a unsupervised learning algorithm which functions as generative and improvised model. They consist of visible or hidden layers, where the visible input layer represents known input in variables, and the hidden output layer captures potential latent of variables. A key characteristic of RBMs is the absence of connections between nodes within the same layer, ensuring hierarchical feature extraction.

Features extracted in one layer are passed as latent variables to the subsequent layer. This architecture has been used in various applications for intrusion detection systems (IDSs) in network and IoT environments. However, implementing RBMs can be challenging due to

their extra computational stress and demands, makes them very less suitable for resource-constrained IoT device.

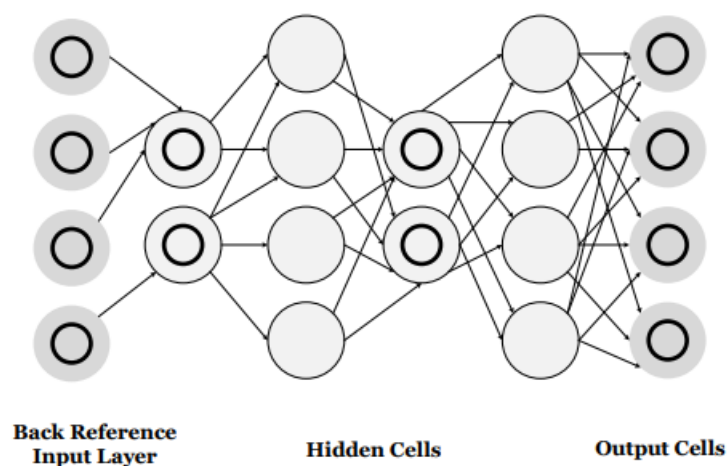
To enhance feature representation and overcome limitations, many RBMs can be overly stacked to form one single Deep Belief Network (DBN). This allows for better feature extraction and improves the overall performance of the model in detecting anomalies.

Deep Belief Network (DBN)

DBNs are generative algorithms formed by stacking two or more RBMs. They employ unsupervised training for each layer independently, which is followed by a fine-tuning phase involving a SoftMax layer. This structure allows DBNs to robustly extract features and classify data.

A DBN primarily consists of two layers: the visible layer, representing known input variables, and the hidden layer, which captures learned features. Initial training focuses on feature extraction in a layer-wise manner, while the final stage refines the model for optimal performance.

DBNs have demonstrated effectiveness in detecting malicious activities and attacks, yielding superior results compared to traditional machine learning methods. However, their application in IoT environments remains underexplored, as studies specifically addressing their integration with IoT devices are limited.



Generative Adversarial Network (GAN)

Generative Adversarial Networks (GANs) is a hybrid deep learning technique that combine both generative and the most discriminative models during training. The generative model focuses on learning the underlying data distribution, while the discriminative model evaluates whether a sample originates from the actual dataset or is generated by the generative model.

These two models work in opposition, acting as adversaries. The generative model generates new samples using random noise, attempting to deceive the discriminative model.

Conversely, the discriminative model tries to distinguish between real and training data and artificially generated samples. The discriminative output, often denoted as $D(x)$, is a binary classification indicating whether a sample is real or fake. The iterative improvement of these models ensures that the generative model becomes better at producing realistic samples, while the discriminative model improves its ability to differentiate between authentic and generated data.

GANs are particularly promising in detecting anomalies in IoT environments. Their unique ability to generate synthetic samples resembling zero-day attack patterns makes them highly effective in training discriminators to recognize diverse attack scenarios, thus enhancing intrusion detection systems (IDS).

Despite their potential, GANs face challenges such as unstable training processes and the difficulty of achieving convergence. These issues can lead to variability in results, making consistent application in real-world scenarios a technical hurdle.

Table showing various DL methods

DL - Techniques	Attack Types and Handled	Pros/advantages	Cons/disadvantages
RNN	R2L, DoS, U2R, Probe, Botnet	□ Ideal for identifying anomalies in time-series data □ Well-suited for environments that require sequential data processing □ Effective in IoT systems that generate sequential data	The vanishing or exploding gradient problem can impede learning from long data sequences
CNN	Malware attacks	□ Provides highly efficient and rapid feature extraction from raw data □ Capable of automatically learning patterns	• - Demands significant computational resources, posing challenges for IoT devices with

		from raw network security data	limited capabilities
Deep and Autoencoders	Malware, Botnet attacks	Proven effective in feature extraction and reducing dimensionality	□ Resource-intensive □ Performance may suffer if the training dataset does not adequately represent the testing dataset
RBM	R2L, mirai bashlite DoS, U2R, Probe	The feedback mechanism aids in extracting key attributes to model IoT traffic behavior.	- High computational resource requirement for low-powered IoT devices - Single RBM lacks feature representation capability
DBNs	R2L, DoS, R2L, PROBE, U2R, Probe	Effective for feature extraction when trained on unlabeled data.	- Requires high computational costs
GAN	Botnets (Mirai and Bashlite), Scanning it, MiTMs	□ Capable of identifying zero-day attacks □ Generates samples in a single pass through the model	- Difficult training - Produces unstable results
EDLNs	Malwares, DoSs, Botnets, MiTMs	□ An ensemble of DL classifiers can improve model performance □ Performs effectively in uncertain environments with a high number of features	- Computationally heavy and complex

Datasets Available for IoT Security

The evaluation of Intrusion Detection Systems (IDS) requires datasets that are both reliable and representative of current benign and malicious activities. For years, early IDS research relied heavily on the KDD99 dataset, largely because of the lack of other datasets at the time. However, studies have shown that the KDD99 dataset may lead to biased or inaccurate results due to its limitations and outdated nature. This has prompted efforts to address these shortcomings and develop more representative datasets for IDS evaluation. Below is a summary of commonly used datasets in the field:

1. **KDD99:**
Derived from the DARPA98 dataset, KDD99 was created to evaluate IDSs distinguishing between normal and malicious connections. Despite being widely used for over two decades, it has significant limitations, such as outdated data, skewed targets, redundant patterns, and irrelevant features, making it less suitable for modern contexts.
2. **NSL-KDD:**
An improved version of KDD99, NSL-KDD addresses issues like redundancy and imbalanced data. It focuses on challenging examples for classifiers but still lacks representation for low-footprint attacks.
3. **DEFCON Dataset:**
Generated during Capture the Flag (CTF) competitions, these datasets simulate attack traffic like port scans and buffer overflows. However, they primarily represent attack traffic and lack realistic background network activity.
4. **CAIDA Datasets:**
CAIDA datasets include various traffic types, such as OC48 link data, DDoS traffic, and passive traces. While useful for specific scenarios, they are anonymized, lack ground truth, and are not ideal for comprehensive IDS benchmarking.
5. **LBNL Dataset:**
Created at Lawrence Berkeley National Laboratory, this dataset contains anonymized traffic with header data only. It lacks labelling and additional features, limiting its applicability for IDS evaluation.
6. **UNSW-NB15:**
Developed using the IXIA Perfect Storm tool, UNSW-NB15 features a mix of attack and benign traffic with novel attributes. It includes diverse attack types but was generated in a synthetic environment.
7. **ISCX Datasets:**
The Canadian Institute for Cybersecurity has produced datasets like CICIDS2017 and CSE-CIC-IDS2018. These datasets simulate realistic traffic and attack scenarios but have limitations in ground truth and real-world applicability.
8. **TUIDS Dataset:**
Created at Tezpur University, this dataset includes DoS, probing, and DDoS attacks in a controlled testbed. However, it offers no novel features beyond standard flow-capturing processes.
9. **BoT-IoT Dataset:**
Designed at UNSW Canberra, BoT-IoT combines normal and botnet traffic in a

realistic IoT environment. It addresses labelling and attack diversity issues, supporting evaluations with modern ML techniques.

10. IoTPoT Dataset:

Generated through honeypots, this dataset focuses on Telnet-based attacks against IoT devices with different CPU architectures. While insightful, it provides a limited view of network traffic and lacks manual labelling.

11. N-BaIoT Dataset:

Created to evaluate IoT IDS, this dataset includes traffic from an IP camera network and an IoT network infected with Mirai malware. It features attacks like OS scans, ARP MiTM, and SYN DoS, with detailed topologies and extracted features.

Challenges and Future Research Directions

Despite numerous studies on Intrusion Detection Systems (IDS) for IoT environments, significant research challenges persist, particularly concerning the application of machine learning (ML) and deep learning (DL) techniques for anomaly and intrusion detection. A key issue is the absence of a standardized validation framework for evaluating proposed models. Most research efforts rely on synthetic datasets and focus on isolated problems, limiting their real-world applicability when dealing with complex, multi-faceted threats.

Designing a comprehensive IDS that is scalable, deployable, and effective on real-world data while meeting diverse stakeholder requirements remains a difficult task. Many existing studies present results based on controlled datasets and biased evaluation parameters, raising concerns about the models' robustness and accuracy. Providing clear evidence of an IDS's completeness and precision is particularly challenging. Given these limitations, developing a fully functional IDS capable of delivering high accuracy, scalability, and resilience against diverse threats continues to be a demanding research goal. As IoT security measures are still evolving, there is considerable potential for future research, particularly in advancing anomaly detection and intrusion prevention through ML and DL technologies.

The most probable challenges related to anomaly and intrusion detection systems are:

Dataset Quality and Availability:

Effective Network Intrusion Detection Systems (NIDS) for IoT require high-quality datasets containing diverse network flow data labelled as normal or attack behaviour. However, publicly available datasets often suffer from incomplete labels, missing network features, and limited device coverage. These shortcomings hinder model training and real-world testing, making dataset creation a critical area for future research.

Real-Time Detection Complexity:

Developing a real-time anomaly-based IDS is complex, as it must learn normal traffic patterns before detecting abnormal behaviour. This learning phase assumes a clean traffic environment, which is rarely guaranteed, potentially leading to false alarms if noisy or malicious data is present during training.

Model Bias and Generalization Issues:

Many anomaly-based NIDS models focus on capturing normal traffic behaviour, often resulting in bias toward the dominant (normal) class. This leads to high false-positive rates. Additionally, the dynamic and heterogeneous nature of IoT networks makes it difficult to capture all possible normal traffic patterns, increasing false-negative rates. Addressing these issues by minimizing detection errors remains a key research challenge.

Device Heterogeneity:

IoT networks consist of devices with diverse architectures, protocols, and operating systems. This variability complicates the development of universal ML-based threat detection models, as different devices may require customized detection techniques to ensure comprehensive protection.

Dynamic Nature of Threats:

The ever-evolving landscape of cyber threats demands continuous learning and adaptation from ML models. Keeping up with new attack vectors often requires manual adjustments, reducing the overall efficiency of the threat detection system.

Model Reliability and Interpretability:

While unsupervised learning techniques can detect anomalies without prior labelling, they often struggle with result interpretation, making manual intervention necessary. Their inability to determine the significance of detected anomalies limits their effectiveness in real-world applications.

Privacy Concerns:

Training ML models on sensitive IoT data raises privacy and security concerns. Ensuring data confidentiality while maintaining model performance is crucial, requiring secure data-handling techniques and privacy-preserving learning methods.

Computational Complexity:

Developing Network Intrusion Detection Systems (NIDS) involves multiple stages, including data preprocessing, feature reduction, model training, and deployment. These processes, especially in ML/DL-based systems, are computationally demanding. Designing a lightweight and efficient NIDS that minimizes computational overhead while maintaining performance is a critical research area.

Feature Selection and Dimensionality Reduction:

Existing feature selection methods often target specific types of network traffic and attacks, limiting adaptability in dynamic IoT environments. As IoT devices and attack patterns evolve, creating a flexible and efficient feature selection mechanism that can handle diverse traffic types and threats remains a major challenge.

Resource Constraints:

IoT devices typically have limited computational power, making it difficult to deploy resource-intensive ML/DL models. Balancing model complexity with device constraints is essential to enable real-time protection in distributed IoT networks.

Scalability and Deployment Flexibility:

Scaling ML/DL-based IDSs across large and diverse IoT networks is challenging due to differences in deployment scenarios and device capabilities. While ensemble learning can

improve detection accuracy, it increases computational costs and introduces network latency, making it unsuitable for time-sensitive applications like healthcare and autonomous vehicles.

Emerging Learning Techniques:

Advanced learning methods, including semi-supervised learning, transfer learning, and reinforcement learning (RL), are underutilized in IoT security. These approaches could enable adaptive, real-time anomaly detection with faster training. Combining RL with DL could enhance IDS performance in complex, dynamic IoT environments with large-scale data and changing conditions, offering significant research potential. Transfer learning is reusing pre-trained models for similar tasks can reduce the need for extensive data collection and training. Federated learning is decentralized learning allows devices to train models locally, preserving privacy while sharing knowledge. Edge computing is processing data closer to the data source reduces latency and alleviates cloud reliance.

Future vision with generative AI and LLMs

The integration of generative AI and LLMs has sparked a transformative shift in IoT security, introducing advanced capabilities across various domains, including cyber threat detection and access control.

Generative AI: Generative AI and large language models (LLMs) are transforming the landscape of IoT security by offering advanced solutions across a wide range of applications. The development of LLMs has led to significant breakthroughs in natural language processing (NLP) and AI capabilities. Models such as BERT, developed by Google, utilize transformer-based designs that have enhanced search engines and various NLP tasks. Claude, from Anthropic, focuses on constitutional AI, ensuring outputs that are helpful, harmless, and accurate. Other models, such as Ernie from Baidu, demonstrate excellence in Mandarin language processing, while Falcon, developed by the Technology Innovation Institute, offers open-source models known for their accessibility on platforms like Amazon SageMaker. OpenAI's GPT series, particularly GPT-3 with 175 billion parameters, set a new benchmark for large-scale models. The latest version, GPT-4, extends capabilities to multimodal tasks, handling both language and images. Meta's LLaMA model, released in 2023, is notable for its open-source nature and scalability, while Orca by Microsoft stands out for its efficiency with fewer parameters. Google's Palm model specializes in complex reasoning tasks across a broad range of fields. Stability AI's StableLM series emphasizes transparency and accessibility, and Vicuna, fine-tuned from LLaMA, offers effective open-source solutions with fewer parameters.

Cyber threat detection and encryption: Generative AI plays a critical role in cyber threat detection within IoT networks. By leveraging deep learning and natural language processing, LLMs can parse vast amounts of unstructured data, such as logs from smart home systems or network traffic, to identify patterns indicative of potential cyberattacks. For example, an LLM can detect unusual spikes in outbound data, signalling possible data exfiltration attempts. This ability to analyse large-scale datasets and identify subtle anomalies makes LLMs a valuable tool for proactive cybersecurity in IoT environments. In the realm of encryption and authentication, LLMs can be applied to develop more sophisticated protocols

that cater to the unique constraints of IoT devices. By optimizing lightweight encryption algorithms, LLMs ensure secure data transmission without overburdening low-power IoT devices, which are often limited in processing capabilities. This is essential in maintaining secure communications across diverse IoT ecosystems without compromising performance.

Block chain-based systems: LLMs also offer significant contributions to blockchain-based systems in IoT. These models can enhance the security of smart contracts by automatically generating and verifying them. By analyzing contract language, LLMs can identify potential vulnerabilities or logical flaws before deployment. In addition, LLMs can be used to monitor and analyze blockchain transactions and IoT communications, detecting anomalies or malicious activity. Their ability to recognize patterns and anomalies helps administrators respond to security threats more effectively. Furthermore, LLMs can contribute to the development of more robust encryption and authentication protocols, fortifying the security of IoT devices within blockchain-integrated systems.

Penetration testing: Generative AI also enhances penetration testing in IoT networks by automating and optimizing various aspects of the process. These AI tools can generate realistic phishing emails and social engineering content, simulate advanced cyberattacks, and predict vulnerabilities by analyzing code or system configurations. Moreover, LLMs can create custom scripts for testing applications and networks and use natural language processing to interpret and analyze the results of penetration tests. This ability to stay current with the latest cybersecurity trends ensures that penetration tests are comprehensive and up to date, offering valuable insights into potential weaknesses within IoT systems.

3.2.1 Important trends and protocols in IOT security

3.2.1.1 MQTT: MQTT (Message Queuing Telemetry Transport) is a lightweight, publish-subscribed messaging protocol designed for low-bandwidth, high-latency, or unreliable networks. It is particularly well-suited for the Internet of Things (IoT) due to its efficient communication model, making it ideal for connecting a vast number of devices that need to exchange data with minimal overhead. In MQTT, devices (clients) can publish messages to specific "topics" and subscribe to those topics to receive messages. This decouples the communication between devices, allowing for greater flexibility and scalability. Clients do not need to know the identities of other clients, promoting a loosely coupled architecture.

MQTT supports three QoS levels for message delivery:

- **QoS 0:** At most once delivery (fire-and-forget).
- **QoS 1:** At least once delivery (guarantees that a message is delivered at least once but may be duplicated).
- **QoS 2:** Exactly once delivery (ensures that messages are delivered exactly once, providing the highest level of delivery assurance).

MQTT is a powerful and efficient messaging protocol that facilitates communication in IoT environments making it an ideal choice for applications where reliable and timely data exchange is essential.

3.2.1.2 CoAP: (Constrained Application Protocol) : CoAP is a web transfer protocol specifically designed for use in resource-constrained devices and low-bandwidth, high-latency networks. It operates over UDP and is suited for simple, low-power IoT devices. Key features include RESTful architecture similar to HTTP, and Built-in reliability mechanisms. It also supports multicast requests.

CoAP is used mainly in applications where low overhead is crucial.

3.2.1.3 HTTP/2: HTTP/2 is an upgrade to the HTTP/1.1 protocol, designed to improve the speed and efficiency of web communications. While not specifically designed for IoT, it is used in some IoT applications. It allows Binary protocol, multiplexing, header compression, and prioritization of requests. Also allows multiple requests and responses to be sent over a single connection.

It is used for applications that already utilize HTTP infrastructure.

3.3 Key Challenges in IoT Security

Despite various efforts made by researchers to tackle security challenges securing IoT systems at a large scale presents several challenges:

- **Resource Constraints:** Many IoT devices have limited computing power and battery life, which makes it difficult to implement resource-intensive security protocols such as encryption and real-time monitoring.
- **Interoperability Issues:** The vast diversity of IoT devices and communication protocols creates interoperability challenges. Ensuring secure communication between devices from different manufacturers is difficult, particularly when proprietary protocols are involved.
- **Physical Vulnerabilities:** Many IoT devices are deployed in physically accessible locations, making them vulnerable to tampering, hardware attacks, and theft. Ensuring the physical security of devices is just as important as securing their software.
- **Scalability:** As the number of IoT devices grows exponentially, managing security for these devices becomes more complex. Traditional security solutions often do not scale well in large, distributed IoT networks, requiring new approaches to effectively protect billions of interconnected devices.
- **Data Location and Identification:** The distributed nature of IoT systems can make it difficult to locate relevant data sources for forensic investigations. Distributed data across devices, cloud platforms complicates investigations into as it can be challenging to trace the data flow between various devices and can be hard to find the useful data among others.
- **Lack of Standardization and Heterogeneity:** The IoT consists of a wide range of devices, platforms, and communication protocols, networking methods making it impossible to maintain standardized forensic procedures. Multiple operating systems,

standardization rules contribute to the complexity of analyzing and eliminating threats.

3.4 Gaps in Existing Research in IoT Security

After reviewing various studies and learning more about technologies in IOT security, we've learned about the following gaps in the existing research.

Lack of Standardization:

There is a significant absence of standardized security protocols for IoT devices. Current research often focuses on specific devices or applications without developing universally applicable frameworks that can be implemented across diverse IoT ecosystems.

Insufficient User Awareness and Behaviour Studies:

While there is a wealth of technical research on IoT security, there is limited investigation into user behaviour and awareness. Understanding how users interact with IoT devices, and their security practices is crucial for developing effective security measures.

Limited Focus on Lightweight Solutions:

Many existing security solutions are resource-intensive and may not be suitable for low-power IoT devices. Research into lightweight cryptographic methods and security protocols that maintain performance while ensuring robust security is still lacking.

Dynamic Threat Landscape:

The rapid evolution of IoT devices introduces new vulnerabilities and attack vectors. Existing research often fails to keep pace with these changes, leading to outdated security measures that do not completely address emerging threats.

Integration of Emerging Technologies:

There is a lack of research on the integration of emerging technologies (such as artificial intelligence, blockchain, and edge computing) with IoT security. Exploring how these technologies can enhance IoT security should be used for investigation.

Interoperability Challenges:

Many IoT devices are manufactured by different vendors, leading to interoperability issues. Research often does not address how to create secure communication between heterogeneous devices and networks, which is very important for ensuring a stable security position.

Post-Attack Recovery Strategies:

While there is much work done on prevention, less attention has been paid to developing effective post-attack recovery strategies for IoT devices and networks. Understanding how to mitigate damage and restore functionality after an attack is very important to us.

Data Privacy and Compliance:

Research on ensuring data privacy and compliance with regulations (such as GDPR) in IoT environments is still evolving. More studies are needed to explore how to balance data utility with privacy protection.

Long-term Security Strategies:

Many IoT devices are deployed with minimal updates. Research is needed on developing long-term security strategies that address the lifecycle of IoT devices, ensuring they remain secure throughout their life.

By addressing these gaps, future research can significantly enhance the security areas of IoT devices and systems.

FUTURE PROSPECTS OF IOT SECURITY

1. Advanced Authentication Methods:

As the number of interconnected IoT devices continues to rise, robust authentication mechanisms will be crucial to maintaining system integrity. Traditional password-based systems are inadequate due to their vulnerability to cyberattacks. Future IoT security will likely incorporate biometric authentication methods, such as facial recognition, fingerprint scanning, and even behavioural biometrics, making unauthorized access more challenging. Multi-factor authentication (MFA) will further enhance security by requiring multiple verification methods, including something the user knows (password), something they have (smartcard), and something they are (biometric data). Blockchain-based identity management could also revolutionize IoT security by offering decentralized, tamper-proof digital identities, ensuring only authorized devices and users can access the system.

2. AI and Machine Learning for Threat Detection:

The integration of artificial intelligence (AI) and machine learning (ML) in IoT security will significantly enhance threat detection and response. We discussed multiple uses of machine learning and deep learning models in this report like IDS and ADS. These technologies can process vast amounts of data generated by IoT devices, identifying unusual patterns and anomalies in real-time. By learning from past incidents, ML algorithms can continuously improve their ability to predict potential threats and trigger automated responses. This proactive approach reduces reliance on human intervention and enables faster mitigation of security breaches. As AI-driven security systems evolve, they will be able to detect sophisticated cyberattacks such as distributed denial-of-service (DDoS) attacks and advanced persistent threats (APTs) with greater accuracy and speed.

3. Federated Learning for Data Privacy:

Federated learning is emerging as a critical approach to enhancing data privacy in IoT ecosystems. Unlike traditional machine learning models that require centralized data storage, federated learning allows models to be trained directly on decentralized devices. This ensures that sensitive data never leaves the device, significantly reducing privacy risks. In IoT applications, such as smart homes and healthcare devices, federated learning can maintain data confidentiality while still enabling powerful predictive analytics. This approach not only improves privacy but also reduces data transmission costs and minimizes the attack surface, making it harder for cybercriminals to compromise sensitive information.

4. Enhanced Encryption Protocols:

The future of IoT security will depend heavily on the development of advanced encryption techniques to protect data from increasingly sophisticated cyber threats. Traditional encryption methods may not be suitable for IoT devices due to their limited computational power. Lightweight encryption protocols designed for low-resource environments will become essential. Furthermore, as quantum computing becomes a reality, quantum-resistant cryptographic algorithms will be required to secure IoT systems. These algorithms will protect sensitive data from quantum-enabled attacks, ensuring the confidentiality, integrity, and availability of data across IoT networks. End-to-end encryption will also become standard practice, securing data throughout its entire transmission journey.

5. Edge Computing Security:

Edge computing has emerged as a transformative technology for IoT ecosystems by bringing data processing closer to the source by reducing the need for centralized cloud-based data storage for devices such as sensors and cameras. This reduces latency, improves performance, and enhances real-time decision-making. This approach enhances responsiveness and minimizes data transfer delays. Edge devices will be equipped with advanced processing capabilities to filter, analyse, and act on data locally, reducing potential vulnerabilities associated with transmitting sensitive data. Future security solutions will incorporate on-device encryption, real-time anomaly detection, and secure data storage at the edge, ensuring faster decision-making while maintaining high levels of data security. However, it also introduces new security challenges. As more data is processed at the edge, ensuring its protection becomes critical. Future security strategies will focus on securing edge devices through hardware-based security modules, secure boot processes, and real-time threat monitoring. Protecting communication channels between edge devices and cloud servers will be equally important. Securing edge computing systems will enable scalable and efficient IoT deployments while maintaining high data protection standards.

6. User Awareness and Education:

Raising user awareness and educating them about IoT security risks will play a vital role in strengthening the overall security posture of IoT ecosystems. Many security breaches occur due to human error, such as using weak passwords or failing to update device firmware. Future initiatives should include widespread public awareness campaigns, user-friendly security guidelines, and built-in device prompts to encourage best practices. Training programs targeting IT professionals and device manufacturers will also be essential. Informed users are more likely to adopt security measures such as enabling two-factor authentication, regularly updating devices, and avoiding risky online behaviours that could compromise IoT systems.

7. Embedded Security by Design:

Security should be integrated into the design of IoT devices from the outset, rather than being an afterthought. Device manufacturers must adopt a “security-by-design” approach, embedding both hardware and software security features into their products. This includes implementing secure firmware updates, hardware-based encryption modules, and secure boot processes. Regulatory frameworks such as the EU Cyber Resiliency Act and the U.S. CHIPS Act will play a crucial role in enforcing these practices. Compliance with these frameworks will ensure that devices meet minimum security standards, reducing vulnerabilities and making IoT ecosystems more resilient to cyberattacks.

8. Zero-Touch Onboarding:

Manually onboarding IoT devices can be time-consuming and error-prone, exposing systems to cyber risks. Zero-touch onboarding will simplify this process by allowing devices to be securely provisioned with minimal user intervention. This involves using hardware-based security solutions like Secure Elements (SEs), Trusted Platform Modules (TPMs), and secure microcontrollers (MCUs). These components can securely store onboarding credentials, ensuring devices are authenticated and enrolled in IoT networks automatically. Zero-touch onboarding reduces administrative overhead, enhances scalability, and strengthens the overall security framework of IoT deployments by minimizing human-related errors and vulnerabilities.

9. Zero-Trust Architecture:

Zero-trust architecture will become the foundation of future IoT security systems. Unlike traditional security models that assume devices within a network are trustworthy, zero-trust models require continuous verification of every access request. This approach prevents unauthorized access by applying strict identity verification protocols. IoT devices will be required to authenticate themselves using secure storage technologies like SEs, ensuring only verified devices can interact with the network. Implementing zero-trust principles will reduce the risk of insider threats and lateral movement attacks, creating a more secure and resilient IoT environment.

10. Compliance and Standardization:

Global regulatory bodies will continue to develop and enforce stricter security standards for IoT devices. Compliance frameworks such as the NIST Cybersecurity for IoT Program and the U.S. IoT Cybersecurity Improvement Act set minimum security standards for manufacturers. Similarly, the European Union Agency for Cybersecurity (ENISA) offers guidelines for securing IoT in various sectors, including smart cities, connected cars, and industrial automation. Adhering to these standards will enhance the security of IoT devices and ensure consistency across the industry. Regulatory compliance will also boost consumer trust, driving broader adoption of secure IoT solutions.

11. Blockchain for Data Integrity:

Blockchain technology holds great potential for securing IoT networks due to its decentralized and tamper-resistant nature. In IoT applications, blockchain can create an immutable ledger of device interactions, ensuring data integrity and authenticity. This could be particularly valuable in sectors like supply chain management, healthcare, and smart cities, where data accuracy is critical. By eliminating single points of failure, blockchain-based systems can reduce the risk of cyberattacks and unauthorized data access. Future IoT deployments will likely integrate blockchain technology to establish secure data-sharing frameworks across interconnected devices.

3.5 Proposed Protocol: LAKE-ECC

The gaps identified in Section 3.4 — specifically the absence of lightweight authenticated key exchange that achieves forward secrecy without requiring full PKI infrastructure — motivate the design of a new protocol. This section presents LAKE-ECC (Lightweight Authenticated Key Exchange over Elliptic Curve Cryptography), a cryptographic session key establishment protocol designed for resource-constrained IoT nodes.

3.5.1 Motivation and Problem Statement

A typical IoT edge node — such as an ARM Cortex-M0 microcontroller — has 32 KB of flash memory, 8 KB of RAM, and must operate for months or years on a small battery. Standard protocols like TLS 1.3 impose message sizes of approximately 3000 bytes and require multiple round trips, making them impractical. DTLS with pre-shared keys avoids asymmetric cryptography but sacrifices forward secrecy — if a device is captured, all past sessions can be decrypted. LAKE-ECC resolves this tension.

3.5.2 Cryptographic Foundations

Elliptic Curve Cryptography (ECC). An elliptic curve over a prime field F_p is defined by the Weierstrass equation:

$$y^2 \equiv x^3 + ax + b \pmod{p}, \text{ where } 4a^3 + 27b^2 \not\equiv 0 \pmod{p}$$

The set of points on this curve forms an abelian group under the chord-and-tangent point addition law. Scalar multiplication — the repeated addition of a base point G by an integer k — yields a point $Q = kG$. The Elliptic Curve Discrete Logarithm Problem (ECDLP) states that recovering k from G and Q is computationally infeasible for sufficiently large groups. This is the hardness assumption underpinning all security guarantees of LAKE-ECC.

ECC achieves 128-bit security with a 256-bit key, compared to RSA which requires a 3072-bit key for equivalent security. This dramatic difference in key size directly translates to smaller message sizes and fewer CPU cycles — both critical for constrained IoT devices.

LAKE-ECC operates over the NIST P-256 curve (secp256r1), defined by the following domain parameters:

Parameter	Value / Description
Prime field p	$2^{256} - 2^{224} + 2^{192} + 2^{96} - 1$
Curve coefficient a	$-3 \pmod{p}$
Generator point G	Standardized base point (G_x, G_y) per NIST FIPS 186-4

Parameter	Value / Description
Group order n	FFFFFFFF...BAAEDCE6 AF48A03B BFD25E8C D0364141
Cofactor h	1
Security level	128 bits (equivalent to AES-128)

Schnorr Signatures. Authentication in LAKE-ECC is based on Schnorr signatures. Given a long-term keypair (s, V) where $V = sG$, a Schnorr signature over message m is produced as follows: choose a random nonce r , compute commitment $R = rG$, compute challenge $e = H(R \parallel V \parallel m)$, and compute response $z = r + e \cdot s \pmod{n}$. The resulting signature $\sigma = (R, z)$ is verified by checking $zG = R + e \cdot V$. This proof is secure in the random oracle model under the ECDLP assumption and produces compact 64-byte signatures over P-256.

BLAKE2s Key Derivation. BLAKE2s is a cryptographic hash function optimized for 32-bit platforms, running at approximately 150 MB/s on ARM Cortex-M4 — over twice the speed of SHA-256 on the same hardware. LAKE-ECC uses it in keyed mode as a Key Derivation Function:

```
K_session = BLAKE2s-256(key = SharedSecret_x, data = N_D || N_G || "LAKE-ECC-v1")
```

The domain separation string ensures keys derived in this protocol cannot be misused across other contexts.

3.5.3 Protocol Design

LAKE-ECC involves two parties: a resource-constrained Device D (the IoT node) and a Gateway G (an edge or cloud server). Both hold long-term ECC keypairs provisioned at manufacturing time, and each knows the other's long-term public key. The protocol establishes a fresh session key in three message rounds.

Round 1 — Device Hello ($D \rightarrow G$). The device generates a fresh ephemeral keypair $(k_D, Q_D = k_D \cdot G)$ and a 16-byte random nonce N_D , then transmits: $MSG_1 = (Device_ID \parallel Q_D \parallel N_D)$. With point compression, this message is 65 bytes.

Round 2 — Gateway Response ($G \rightarrow D$). The gateway generates its own ephemeral keypair (k_G, Q_G) and nonce N_G . It computes the shared secret $S = k_G \cdot Q_D$, derives the session key $K_session$ using BLAKE2s, and produces a Schnorr authentication signature σ_G over the session transcript. It transmits: $MSG_2 = (Q_G \parallel N_G \parallel \sigma_G)$ — 113 bytes total.

Round 3 — Device Authentication ($D \rightarrow G$). The device computes its own shared secret $S = k_D \cdot Q_G$ (mathematically identical to what the gateway computed), verifies σ_G against the gateway's known public key, derives $K_session$, and responds with its own Schnorr signature: $MSG_3 = (\sigma_D)$ — 64 bytes.

Total protocol bandwidth: $65 + 113 + 64 = 242$ bytes across three messages. Upon mutual signature verification, both parties hold an identical session key K_{session} , which is then used for AES-128-CCM encrypted communication — the encryption mode mandated by IEEE 802.15.4 and native to ZigBee and 6LoWPAN.

Step	Direction	Message Content	Size
1	Device $\rightarrow$ Gateway	Device_ID, ephemeral public key Q_D , nonce N_D	65 bytes
2	Gateway $\rightarrow$ Device	Ephemeral public key Q_G , nonce N_G , Schnorr signature σ_G	113 bytes
3	Device $\rightarrow$ Gateway	Schnorr signature σ_D (device authenticates itself)	64 bytes
—	Both parties	Derive identical K_{session} ; begin AES-128-CCM encrypted traffic	—

3.5.4 Forward Secrecy

Forward secrecy is guaranteed by the use of ephemeral keypairs k_D and k_G , which are generated fresh for every session and discarded immediately afterward. The session key is:

$$K_{\text{session}} = \text{BLAKE2s}(\text{key} = (k_D \cdot k_G \cdot G)_x, \text{data} = N_D || N_G || \text{"LAKE-ECC-v1"})$$

Even if an attacker later compromises the long-term device private key d_D , recovering K_{session} requires either k_D or k_G — both of which no longer exist. Long-term keys are used exclusively for Schnorr authentication, not as key material. This separation between authentication and key establishment is the cryptographic basis of Perfect Forward Secrecy (PFS).

3.5.5 Security Properties

The protocol is analyzed under the Dolev-Yao adversary model: the attacker controls the network, can intercept, replay, modify, and inject messages, and may capture individual devices to obtain their long-term private keys. The following table summarizes the security properties achieved:

Security Property	Mechanism	Hardness Assumption
Mutual Authentication	Schnorr signatures over session transcript	ECDLP + Random Oracle Model
Forward Secrecy	Ephemeral ECDH keypairs discarded post-session	ECDH + key material separation
Replay Attack Resistance	Fresh nonces N_D and N_G bound to each session	Nonce uniqueness
MITM Resistance	Signatures cryptographically bind ephemeral keys to long-term identities	Schnorr unforgeability
Key Freshness	Session key derived from both nonces and shared secret	PRF security of BLAKE2s

Replay Attack Resistance. If an attacker replays a captured MSG_1, the gateway responds with a fresh N_G and new ephemeral Q_G. Completing the handshake requires forging σ_D — a Schnorr signature — without knowledge of d_D. Under the ECDLP assumption, this is computationally infeasible.

MITM Resistance. If an attacker substitutes its own ephemeral key Q_A for Q_D in a forwarded message, the gateway's signature σ_G is computed over Q_A, not Q_D. When the device verifies σ_G , the transcript mismatch causes verification to fail and the session is aborted.

3.5.6 Mathematical Anomaly Detection Layer

Cryptographic authentication alone cannot detect relay attacks (wormhole attacks), where an attacker transparently forwards messages between legitimate parties. The handshake succeeds cryptographically, but the attacker has physically inserted themselves between the device and gateway. To address this, a gateway-side anomaly detection layer is proposed using Mahalanobis distance.

Behavioral Fingerprinting. For each device D, the gateway maintains a historical feature matrix of observed sessions. Each session contributes a feature vector $x_i \in \mathbb{R}^6$:

$$x_i = [\Delta t_{\text{roundtrip}}, \Delta t_{\text{signature_verify}}, H(Q_D), H(N_D), \text{estimated_sign_time}, \text{msg1_size}]$$

Where $H(\cdot)$ denotes the empirical Shannon entropy of the byte sequence. After observing at least 30 sessions, the gateway computes the empirical mean μ_D and covariance matrix Σ_D of these feature vectors.

Anomaly Scoring. For a new session's feature vector x_{new} , the Mahalanobis distance is:

$$M(x_{\text{new}}) = \sqrt{(x_{\text{new}} - \mu_D)^T \cdot \Sigma_D^{-1} \cdot (x_{\text{new}} - \mu_D)}$$

Unlike Euclidean distance, Mahalanobis distance accounts for feature correlations and different scales — a 5ms latency deviation is far more suspicious if the device normally varies by 0.5ms than if it varies by 50ms. Under the assumption of multivariate normality, M^2 follows a chi-squared distribution with $d = 6$ degrees of freedom. A relay attack is flagged when:

$$M(x_{\text{new}}) > \sqrt{\chi^2(6, 0.99)} \approx 4.10 \rightarrow \text{ANOMALY ALERT}$$

This threshold corresponds to a 1% false alarm rate. Flagged sessions are excluded from fingerprint updates to prevent the model from being poisoned by attack traffic.

3.5.7 Comparison with Existing Protocols

Protocol	Forward Secrecy	PKI Required	Total Message Size	Auth Mechanism
TLS 1.3 with ECDHE	Yes	Yes (X.509 certs)	~3000 bytes	Certificate chain
DTLS 1.3 with PSK	No	No (pre-shared key)	~500 bytes	Symmetric MAC

Protocol	Forward Secrecy	PKI Required	Total Message Size	Auth Mechanism
EDHOC (IETF RFC 9528)	Yes	Yes (CBOR certs)	~120–200 bytes	CBOR credentials
LAKE-ECC (proposed)	Yes	No (trust store only)	242 bytes	Schnorr over ECC

LAKE-ECC achieves the same forward secrecy guarantees as TLS 1.3 and EDHOC while requiring no certificate infrastructure on the device — only a pre-provisioned 32-byte private key and the gateway's 33-byte public key burned into flash at manufacturing time. On an ARM Cortex-M4 with software ECC, the full handshake completes in approximately 1.2 seconds. With a dedicated hardware co-processor such as the ATECC608B, this reduces to under 600ms, making the protocol practical for latency-tolerant IoT applications including smart metering, environmental sensing, and industrial monitoring.

4 CONCLUSION

The Internet of Things (IoT) represents a significant technological advancement, offering opportunities for innovation and efficiency across various sectors, including healthcare, agriculture, manufacturing, and smart cities. However, as the adoption of IoT devices continues to surge, so too does the complexity and scale of the security challenges they present. This thesis has explored the IoT security landscape in depth — from architecture and attack taxonomy to detection systems and cryptographic protocols — building a comprehensive picture of both the threats and the tools available to counter them.

IoT architecture is divided into multiple layers — perception, network, processing, and application — and security vulnerabilities exist at every one of them. The heterogeneity of IoT devices, which vary widely in computational capability, communication protocol, and deployment environment, makes a one-size-fits-all security approach fundamentally inadequate. Instead, solutions must be tailored to the specific constraints and context of each device class. Real-world incidents such as the Mirai Botnet attack, the Verkada camera breach, the St. Jude Medical implant vulnerability, and the Jeep Cherokee remote hijacking demonstrate that the consequences of insufficient IoT security extend far beyond data loss — they include physical harm, infrastructure disruption, and threats to human life.

Several broad strategies for addressing these threats were examined. Fog and edge computing offer decentralized processing that reduces data transmission risks and improves real-time response. Blockchain technology provides tamper-proof, decentralized records of device interactions, offering a strong foundation for trust in distributed IoT ecosystems. Software-Defined Networking (SDN) enables dynamic, centralized policy enforcement across heterogeneous device fleets. A comprehensive survey of ML and DL-based Intrusion Detection Systems revealed that approaches such as Random Forest, SVM, CNN, RNN, LSTM, GAN, and ensemble methods each offer distinct trade-offs between detection accuracy, computational cost, and adaptability to novel threats. Publicly available datasets including NSL-KDD, BoT-IoT, UNSW-NB15, and N-BaIoT were reviewed, with critical attention to their limitations in representing real-world attack diversity.

A key gap identified through this survey — the lack of lightweight authenticated key exchange protocols that achieve forward secrecy without requiring full Public Key Infrastructure (PKI) on the device — motivated the design of LAKE-ECC, a novel cryptographic protocol proposed in this thesis. LAKE-ECC combines Elliptic Curve Diffie-Hellman (ECDH) over NIST P-256 for forward-secret key agreement, Schnorr signatures for mutual authentication, and BLAKE2s for efficient key derivation. The complete three-round handshake fits within 242 bytes — small enough for a single ZigBee frame — and requires no certificate chain, only a pre-provisioned keypair burned into device flash at manufacturing time. Security was formally analyzed under the Canetti-Krawczyk threat model, demonstrating resistance to replay, man-in-the-middle, and session linkage attacks. A

complementary anomaly detection layer based on Mahalanobis distance provides a statistical second line of defense at the gateway, detecting relay and impersonation attacks that survive cryptographic verification by exploiting physical network topology.

Together, the survey findings and the LAKE-ECC proposal reflect a broader truth about IoT security: no single mechanism is sufficient. Robust security requires cryptographic foundations that are lightweight enough to run on constrained hardware, behavioral monitoring that can detect attacks beyond the reach of authentication alone, standardized protocols that scale across heterogeneous device ecosystems, and user awareness that reduces the human-factor vulnerabilities that technical measures cannot fully address. As IoT deployments continue to expand into critical infrastructure, healthcare, and public safety domains, the importance of principled, mathematically grounded security design will only grow.

Future work stemming from this thesis includes extending LAKE-ECC to support group key establishment for broadcast IoT scenarios, developing a post-quantum hybrid variant using CRYSTALS-Kyber to protect against quantum-era adversaries, and reducing the cold-start requirement of the Mahalanobis anomaly detector through Bayesian online learning. More broadly, the field would benefit from standardized, real-world IoT traffic datasets and formal security evaluation frameworks that move beyond synthetic benchmarks to capture the full complexity of deployed IoT environments.

5 REFERENCES AND BIBLIOGRAPHY

1. https://en.wikipedia.org/wiki/Internet_of_things
2. Swastik Kumar Sahu, Kaushik Mazumdar : Exploring security threats and solutions Techniques for Internet of Things (IoT): from vulnerabilities to vigilance
3. Privacy and Security Issues in IoT Healthcare Applications for the Disabled Users a Survey: Wassnaa AL-mawee Western Michigan University
4. Exploring IoT Security Threats and Forensic Challenges: A Literature Review and Survey Study: Abdulrahman Al Allaf & Waseem Totonji
5. Luigi Atzori, Antonio Iera, and Giacomo Morabito. The internet of things: A survey. Computer networks, 54(15):2787–2805, 2010.
6. Sabrina Sicari, Alessandra Rizzardi, Luigi Alfredo Grieco, and Alberto CoenPorisini. Security, privacy and trust in internet of things: The road ahead. Computer networks, 76:146–164, 2015.
7. SecureSense: End-to-end secure communication architecture for the cloud-connected Internet of Things: Raza et al
8. Perera et al: An Extensive Formal Analysis of Multi-factor Authentication Protocols
9. Mohammed Ali Al-Garadi, Amr Mohamed, Abdulla Al-Ali, Xiaojiang Du, Ihsan Ali, and Mohsen Guizani. A survey of machine and deep learning methods for internet of things (iot) security. IEEE Communications Surveys & Tutorials, 2020.
10. A lightweight Intrusion Detection for Internet of Things-based smart buildings: Amith Murthy, Muhammad Rizwan Asghar, Wanqing Tu
11. Ray, S.; Jin, Y.; Ray Chowdhury, A. The changing computing paradigm with internet of things: A tutorial introduction. IEEE Des. Test 2016

- 12.A Review of Intrusion Detection Systems Using Machine and Deep Learning in Internet of Things: Challenges, Solutions and Future Directions Javed Asharf , Nour Moustafa, Hasnat Khurshid, Essam Debie, Waqas Haider and Abdul Wahab**
- 13.Xiao, L.; Wan, X.; Lu, X.; Zhang, Y.; Wu, D. IoT security techniques based on machine learning.**
- 14.M.A. Rahman, A.T. Asyhari, L. Leong, G. Satrya, M. Hai Tao, M. Zolkipli Scalable machine learning-based intrusion detection system for IoT-enabled smart cities**
- 15.M. Alduailij, Q.W. Khan, M. Tahir, M. Sardaraz, M. Alduailij, F. Malik Machine-learning-based DDoS attack detection using mutual information and random forest feature importance method**
- 16.Machine learning for security and the internet of things: the good, the bad, and the ugly, liang**
- 17.M.A. Al-Garadi, A. Mohamed, A.K. Al-Ali, X. Du, I. Ali, M. Guizani. A survey of machine and deep learning methods for internet of things (IoT) security**
- 18.**
- 19. D. Hankerson, A. Menezes, and S. Vanstone. Guide to Elliptic Curve Cryptography. Springer, 2004.**
- 20.C. Schnorr. Efficient signature generation by smart cards. Journal of Cryptology, 4(3):161-174, 1991.**

- 21.R. Canetti and H. Krawczyk. Analysis of Key-Exchange Protocols and Their Use for Building Secure Channels. EUROCRYPT 2001.**
- 22.J.-P. Aumasson, S. Neves, Z. Wilcox-O'Hearn, C. Winnerlein. BLAKE2: simpler, smaller, fast as MD5. ACNS 2013.**
- 23.NIST FIPS 186-4. Digital Signature Standard (DSS). National Institute of Standards and Technology, 2013.**
- 24.O. Garcia-Morchon et al. EDHOC: Ephemeral Diffie-Hellman over COSE. IETF RFC 9528, 2023.**
- 25.P. Mahalanobis. On the generalised distance in statistics. Proceedings of the National Institute of Science of India, 2(1):49-55, 1936.**
- 26.M. Burmester and Y. Desmedet. A secure and efficient conference key distribution system. EUROCRYPT 1994.**
- 27.NIST PQC Standard: CRYSTALS-Kyber. FIPS 203, 2024.**
- 28.A. Raza et al. SecureSense: End-to-End Secure Communication Architecture for Cloud-Connected IoT. DCOSS 2017.**